Ciberseguridad. Riesgos y amenazas en red

Unidad 1. Identidad digital

1. Capacidad de identificación personal en el ámbito digital
    1. ¿Que es la identidad digital?

       Se refiere a una entidad online que puede ser reclamada y utilizada por una organización, un dispositivo electrónico o un individuo en el mundo virtual.

       La identidad digital de una persona es una compilación de datos sobre ella misma, representada en formato digital. Esta información de datos puede incluir información variada como la fecha de nacimiento o las redes sociales que utiliza, entre otros detalles.

       Información del video:

       ¿Quienes somos en la red?

       Desde que internet se instaló en nuestras vidas, somos lo que publicamos, lo que compartimos, con quien nos relacionamos, e incluso lo que visitamos desde nuestros dispositivos, todo este rastro que vamos dejando es lo que compone nuestra identidad digital.

       Ejemplo: Una chica que publica en redes sociales decide ir a un concierto, pero como tiene que trabajar decide inventarse que está enferma, para poder asistir al concierto, como publica fotos y comentarios de dicho concierto, cuando vuelve al trabajo se habían enterado que no había estado enferma y que fue al concierto, indagando más encontraron comentarios negativos de su puesto de trabajo y compañeros.

       Construir una identidad digital positiva , preguntarnos:

       - ¿Que quiero que se sepa de mi?
       - ¿Puede afectarme negativamente en el futuro?
       - si subo este contenido me perjudicará a mi o a otras personas?

       La identificación personal en el ámbito digital se refiere a la forma en que las personas se autentican e identifican en la red.

       Nos podemos autenticar mediante:

       - uso de contraseñas
       - pins
       - huellas dactilares
       - reconocimiento facial
       - otros medios biométricos

La identificación personal es esencial para garantizar que sólo las personas autorizadas tengan acceso a cuentas y sistemas online. **Sin embargo, también puede ser un punto débil si no se gestiona adecuadamente, lo que puede llevar a la vulneración de la seguridad digital.**

La manera en que protegemos y gestionamos esta identidad digital tiene un impacto directo en nuestra seguridad en línea. Medidas de seguridad: exposición de datos sensibles, robo de identidad, otras amenazas cibernéticas.

La ciberseguridad se enfoca en la protección de sistemas y datos contra esas amenazas, y gran parte de esta protección gira en torno a garantizar que sólo las personas autorizadas tengan acceso a la identidad digital de una persona.

La gestión adecuada de la identidad personal en línea **es un componente clave de cualquier estrategia de ciberseguridad efectiva** y, comprender que **esta relación es esencial para protegerse en un entorno digital cada vez mas complejo y peligroso.**

2. La seguridad de la información

Es un **conjunto de técnicas y medidas para controlar la globalidad de los datos manejados por una organización y asegurar que no salgan del sistema establecido** por dicha empresa.

Los datos son un activo vital para la organización: bienes tangibles y bienes intangibles

Estos tipos de sistemas establecidos por las organizaciones se basan en las nuevas tecnologías y por lo tanto, la seguridad de la información se ocupará de dichos datos, a los que sólo podrá acceder usuarios debidamente autorizados.

La seguridad de la información debe de tener 3 cualidades principales:

- **critica**: ya que **es una pieza fundamental** para que la empresa pueda funcionar sin asumir demasiados riesgos.
- **valiosa**: Ya que los datos que se salvaguardan **son esenciales para el funcionamiento de la organización.**
- **sensible:** Ya que al sistema solo se podrá acceder si se tiene la debida autorización.

Seguridad de la información =/ Seguridad de los sistemas de la información o seguridad informática.

ISO/IEC 27001 **La seguridad informática consiste en la implantación de un conjunto de medidas técnicas destinadas a preservar la confidencialidad, la integridad y la disponibilidad de la información,** pudiendo además abarcar otras propiedades , como la autenticidad, la responsabilidad, la fiabilidad, y el no repudio.

3. Modelo del ciclo de vida: consta de 4 etapas:
    - Evaluación: Se debe encontrar la estrategia o metodología que te ayude a conocer tu estado real en seguridad. Que te muestre las vulnerabilidades reales a las que te enfrentas. Lo mas objetiva posible que te permitirá:
        - **Analizar las vulnerabilidades** encontradas.
        - **Ordenarlas** para ver que prioridades tienes y las acciones que te llevarán a tener una visión general.

        - **De que manera transversal comunicarlas**, para que todo el mundo sea consciente del estado de las cosas, con un lenguaje lo más sencillo posible para tal efecto.
    - Diseño: Una vez hecha la evaluación se procede a diseñar una solución para que ataque y minimice los aspectos encontrados siendo conscientes de:
        - los recursos y de las prioridades
        - Establecer métricas que nos ayuden a ver los éxitos y fracasos de la implementación.
        - Diseñar los pasos siguientes.
    - Implementación: Poner en marcha el diseño establecido:
        - Documentar los problemas.
        - Aumentar la documentación con la solución a estos problemas.
        - Comunicar y evaluar todo el proceso.
    - Administración y soporte: Hacer un mantenimiento y soporte
        - Medir con respecto a las métricas de soporte y contrastarlas con las de implementación.
        - Comunicar constantemente el estado de las cosas.
        - Documentar nuevas debilidades encontradas.

4. Principios de protección:

   Recuerda:

   Los datos son un activo vital para la organización: bienes tangibles e intangibles

   Aspectos fundamentales:

   La seguridad de los sistemas de información asegura 3 aspectos: confidencialidad, disponibilidad e integridad. Ademas de abarcar otras propiedades como la autenticidad, la responsabilidad, la fiabllidad y el no repudio.

   Tendremos que establecer estrategias que recojan las diferentes políticas de actuación, para cada uno de los aspectos fundamentales.

   Establecer el uso de tecnologías, incluir controles de seguridad y todos los procesos que se van a llevar a cabo, para detectar, los riesgos a los que se puede ver expuesto el sistema.

   ¿En que consisten esos aspectos fundamentales?

   - **Confidencialidad**: Conlleva que la información sea accesible, únicamente, por el personal autorizado para ello.

     NEED-TO-KNOW: Hace referencia a que la información solo debe ponerse a disposición de las personas, entidades o personas autorizados para su acceso. Ejemplo:
     - Robo de información a través de internet.
     - Divulgación no autorizada de dicha información confidencial a través de redes sociales.
     - Acceso por parte de un empleado sin permisos asignados.

- **Integridad**: Hace referencia a que la información sea correcta y esté libre de modificaciones y errores, ya que si no fuese así, podríamos tomar decisiones erróneas. Ejemplo:
    - Modificación de un informe de ventas por parte de un empleado, ya sea malintencionado o por un error humano
- **Disponibilidad**: La información debe de ser accesible cuando sea necesaria. Ejemplo:
    - Imposibilidad de acceder a un email corporativo debido a errores de configuración, incluso, cuando el sistema se cae.
- **No repudio**: Ninguna de las partes involucradas en una operación repudiará la información, es decir, esta acción constituye la garantía de la inexistencia de negación.
- **Autenticación**: Garantizar el acceso a recursos de la organización , únicamente a las personas autorizadas para ello, se consigue a través de la autenticación de la identidad del usuario, siendo además la única garantía de que un interlocutor sea quien dice ser.

  Factores de autenticación:

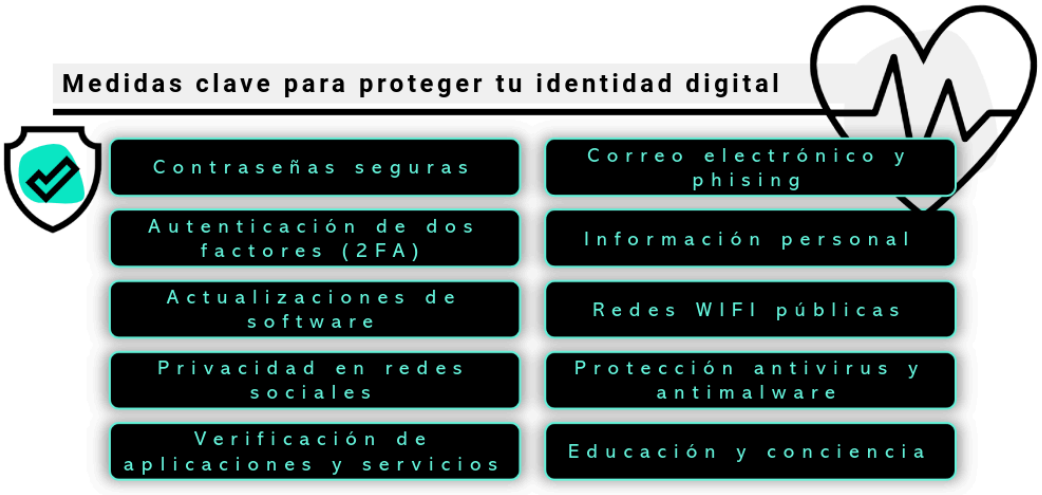
  Consiste en confirmar al usuario, máquina o dispositivo, compararando credenciales con datos recogidos una base de datos, recogidos anteriormente siendo autorizados por una persona responsable antes de haber recibido el acceso.

  Por ejemplo: al consultar el email introduciendo usuario y contraseña.

  Hay nuevos factores de autenticación:

    - Pregunta de seguridad
    - certificado digital: es el único medio que garantiza técnica y legalmente la identidad de una persona en internet , además permite la firma electrónica de documentos (consta de una pareja de claves criptográficas, una ṕublica y una privada que se crean con un algoritmo matemático), lo que hace que una clave solo puede descrifrarse con la otra.
    - tarjeta inteligente: es un dispositivo físico de seguridad, del tamaño, forma y aspecto de una tarjeta de crédito, resistente a la adulteración y copia.
    - factores biométricos: huella dactilar o reconocimiento facial : se usa en operaciones bancarias, teléfonos móviles y acceso a aplicaciones.

2. Conocimiento sobre la protección de nuestra identidad digital:



Medidas para proteger tu identidad digital:

1. Contraseñas seguras: Utiliza contraseñas fuertes y únicas para todas tus cuentas en línea. Evista contraseñas obvias como "123456" o "password". Considera el uso de administradores de contraseñas para gestionar de manera segura sus credenciales.
2. Autenticación en 2 factores (2FA): Habilita la autenticación de dos factores siempre que sea posible. Esto añade una capa adicional de seguridad, ya que incluso si alguien roba tu contraseña, aún necesitarían un segundo factor (como un código enviado a tu teléfono) para acceder a tu cuenta.
3. Actualizaciones de software: Mantén tus dispositivos y aplicaciones actualizados con las últimas actualizaciones de software. Las actualizaciones suelen incluir parches de seguridad importantes.
4. Privacidad en redes sociales: Revisa y ajusta la configuración de privacidad en tus perfiles de redes sociales para controlar quien puede ver tu información y que compartes públicamente.
5. Verificación de aplicaciones y servicios: Antes de usar una nueva aplicación o servicio en línea , verifica su autenticidad y revisa las opiniones de otros usuarios. Evita descargar aplicaciones sospechosas o hacer click en enlaces no confiables.
6. Correo electrónico y phising: Sé cauteloso con los correos electrónicos sospechosos o no solicitados. No hagas click en enlaces o descargues archivos adjuntos de fuentes desconocidas. Los estafadores suelen utilizar el phising para robar información.
7. Información personal: Limita la cantidad de información personal que compartes en línea. Cuanto más información se disponga sobre ti en línea, mayor será el riesgo de que alguien pueda utilizarla de maneraindebida.
8. Redes wifi publicas: Ten cuidado al conectarte en redes wifi públicas, ya que pueden ser menos seguras. Siempre utiliza VPN (Red Privada Virtual) cuando te conectes a una red wifi pública para cifrar tus datos.
9. Protección antivirus y antimalware: Instala y mantén un software de seguridad actualizado en tus dispositivos para protegerte contra virus y malware.
10. Educación y conciencia: Mantente informado sobre las últimas amenazas y mejores prácticas de seguridad en línea. La educación y la conciencia son fundamentales para mantener tu identidad digital segura.

Recuerda: La protección de tu identidad digital es un esfuerzo continuo: Para estar siempre alerta y tomar medidas proactivas. Para mantener tus datos online seguros.

3. Conocimiento sobre los derechos asociados a la identidad digital

Proteger y garantizar derechos asociados a la identidad digital:

1. Derecho a la privacidad: Todos tiene el derecho de controlar quien accede a su información personal en línea y cómo se utiliza. Esto implica la capacidad de gestionar la configuración de privacidad en sitios web y aplicaciones, así como la opción de no ser rastreado sin consentimiento.
2. Derecho al consentimiento informado: Es fundamental informar a las personas sobre cómo se recopila, utiliza y comparte su información online. Deben poder dar su consentimiento de manera informada antes de que se recopile o utilice su información personal.
3. Derecho al olvido: Las personas tienen derecho de solicitar la eliminación de sus datos personales de sitios web y bases de datos en línea, especialmente cuando la información ya no es relevante o cuando retiran su consentimiento para utilizarla.
4. Derecho a la portabilidad de los datos: Las personas tienen derecho a recibir una copia de sus datos personales en un formato estructurado y legible por máquina. Esto facilita la transferencia de datos entre servicios en línea.
5. Derecho a la rectificación: Las personas tiene derecho de corregir cualquier información inexacta o incompleta que se encuentre en línea sobre ellos.
6. Derecho a la seguridad de datos: Las empresas y organizaciones que recopilan y almacenan datos personales tienen la responsabilidad de protegerlos de accesos no autorizados y de violaciones de seguridad. Esto incluye implementar medidas de seguridad adecuadas como la encriptación de datos.
7. Derecho a la no discriminación: Nadie debe ser discriminado en línea debido a su identidad, que incluye su raza, género, orientación sexual, religión u otras características personales.
8. Derecho a la transparencia: Las empresas y organizaciones deben ser transparentes acerca sobre como recopilan , utilizan y comparten los datos personales. Esto incluye proporcionar información clara sobre las políticas de privacidad y los términos de servicio.
9. Derecho a denunciar: Las personas tienen el derecho de denunciar cualquier uso indebido de sus datos personales a las autoridades de protección de datos y buscar reparación en caso de violaciones a la privacidad.

Importante:

Muchos países y jurisdicciones han implementados leyes y regulaciones para proteger estos derechos, como el Reglamento General de Protección de Datos (RGPD) de la Unión Europea.

Las personas tienen que estar informadas sobre sus derechos en línea.

Las organizaciones tienen que cumplir con las normativas de privacidad para garantizar una identidad digital segura y protegida.

Información que se considera de carácter personal:

1. Nombre de pila: a no ser que sea muy general

2. Cualquier tipo de dato bancario.
3. Dni, numero de la seguridad social, pasaporte o cualquier tipo de documento legal.
4. Datos relacionados con credenciales personales (usuario y contraseña)
5. Todos los datos relacionados con nuestra salud, como el historial médico.
6. Otros tipos de datos relacionados con ideologías, como religiosas, políticas u orientación sexual.

¿Cualquier servicio online me puede pedir sin mas estos datos personales?

Todos tienen que informarte sobre el derecho a la privacidad y protección de datos, informarte para que se van a utilizar, que tratamiento se les va a dar, indicar el uso y tiempo de guardado , como ejercer el derecho de los datos que estas cediendo al servicio, rectificación, oposición,..

¿Que puedes hacer si ya no quieres que una empresa ya no haga uso de tus datos ? Solicita su eliminación, Por ejemplo si quieres borrar tus datos de tu cuenta en una red de compras, una red social, tendrás que buscar dentro del propio portal o tienda web cuando estés logeado, dar de baja la cuenta en la configuración, solicitada la eliminación la página deberá eliminar toda tu información, en caso de que no encuentres dicho apartado dentro de la web, puedes contactar con el servicio de atención al cliente.

¿Y si aparecen tus datos en el buscador? Puedes ejercer el derecho de supresión o derecho al olvido, :

- si tus datos personales no son necesarios en relación con los fines para los que fueron recogidos o tratados de otro modo.
- Si el tratamiento de tus datos se ha basado en el consentimiento que prestaste a la persona responsable, y retiras el mismo
- O si tus datos personales se han tratado ilicitamente.

Para ello dirigete al buscador en el que aparecen los datos que deseas eliminar, rellena el formulario de supresión y en caso de que no te den respuesta, pon una reclamación en la Agencia Española de Protección de Datos (www.aepd.es)

Para conocer mas cuales son tus derechos puedes consultar la web www.aepd.es o www.incibe.es/ciudadania o en el teléfono: 017, whatsapp: 900116117, telegram: @INCIBE017 para ayuda en ciberseguridad. (Instituto Nacional de Ciberseguridad)

4. Conocimiento Avanzado de los aspectos de navegación segura por internet
    1. Como conectarnos a internet de forma segura.

       La mayoría de las redes wifis publicas y gratuitas carecen de seguridad, lo que nos expone a un riesgo de que los ciberdelicuentes puedan interceptar cualquier información o archivo que compartamos, ya sea un correo electrónico, una contraseña, o iniciar una sesión o un mensaje dirigido a un ser querido. Para hacer que sea seguro:

        1. Verificar la autenticidad de la red

           En ocasiones los ciberdelincuentes crean redes falsas que se asemejan al nombre de la red oficial. Por ejemplo, la red wifi de un restaurante podría llamarse "ComercioWifi" , mientras que la del ciberdelicuente podría ser "1_ComercioWifi"

2. Evitar compartir información sensible.

   Para prevenir que nuestra información caiga en manos equivocadas debemos de abstenernos de ingresar nuestro nombre de usuario y contraseña en sitios web o, de enviar correos electrónicos mientras estemos en una red pública.

3. Mantener nuestros dispositivos y aplicaciones actualizados.

   Así minimizaremos la posibilidad de que los ciberdelincuentes aprovechen las vulnerabilidades o fallos en nuestro sistema.

4. Instalar y mantener actualizado un antivirus en nuestro dispositivo.

   El antivirus escaneará nuestro dispositivo en busca de amenazas basadas en software malicioso, las comparará con su base de datos y las eliminará si fuese necesario.

5. Preferir sitios web seguros

   Las páginas web que utilizan https y cuentan con un certificado de seguridad son siempre mas seguras, ya que cifran nuestros datos y reducen los riesgos.

6. Usar la navegación privada.

   Esta función nos permite visitar páginas web sin que el navegador almacene información sobre las web que hemos visitado.

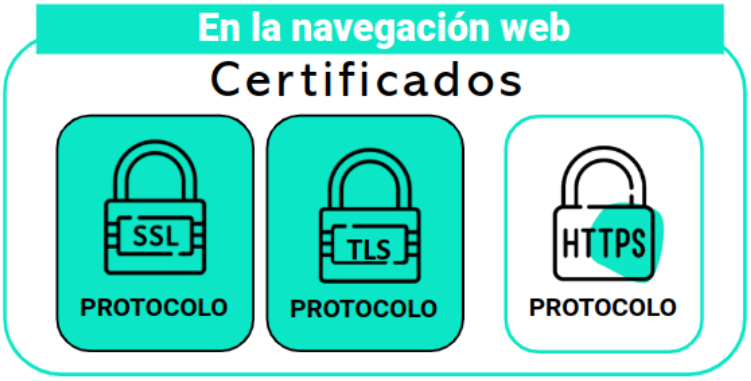
5. Capacidad de identificación y uso de protocolos seguros en internet

   1. Certificados digitales

      Son archivos electrónicos que se generan para las organizaciones por proveedores autorizados de servicios de certificación.

      Estos certificados son esenciales para establecer la confianza de los usuarios.

      Por ejemplo, si tienes un sitio web y deseas garantizar a los usuarios que sus datos estarán seguros y encriptados cuando los compartan en tu sito, puedes contratar a una empresa que emita un certificado digital de confianza si tu sitio cumple con los requisitos necesarios.



      SSL (Secure Socket Layer o Capa de Puertos Seguros que se traduce como Capa de Conexiones Seguras), es un **protocolo de encriptación que emplea certificados digitales para asegurar comunicaciones seguras a través de internet.**

      TLS (su sucesor mas seguro Transport Layer Security o Seguridad de la Capa de Transporte), que se basa en SSL, lo que los hace completamente compatibles.

HTTPS Para acceder a sitios web que tienen un certificado SSL/TLS en su dominio, se utiliza el protocolo HTTPS. Básicamente HTTPS, combina el protocolo HTTP (utilizado para las solicitudes web) con SSL/TLS para establecer conexiones cifradas en los sitios web

¿Que significa que una web empiece por HTTPS?:

Es un protocolo que cifra la información para que terceros no puedan acceder a ella aunque intercepten la comunicación , cuando una pagina utiliza este protocolo, significa que está utilizando tres capas de seguridad :

1. cifrado: (tener los datos a salvo aunque alguien espie),
2. integridad: para que no se puedan modificar los datos intercambiados en la transmision,
3. autenticación: para asegurar que el usuario se eté comunicando con el sitio web que quiere.

Ejemplos: de datos que protegeremos con este protocolo, datos personales como dni,.., datos bancarios, contraseñas de redes sociales o correo electrónico, ideologias, datos médicos, documento, fotografias o videos personales.

Hay que tener en cuenta que una página no es fraudulenta por no utilizar HTTPS, simplemente nos exponemos a mas riesgos con ciberdelincuentes, a la hora de que nos roben datos.

Se debe evitar las urls que no sean de https, si vamos a utilizar datos que sean sensibles.

¿Que significa el candado que aparece al lado de algunas urls?

Significa que tiene un certificado digital, que asegura que la comunicación que se establece entre un usuario y el servidor de dicha web, está protegida al viajar la información de manera cifrada. Además se asegura su integridad, es decir que no se manipula la información.

Si haces click sobre el candado te mostrará información de que está protegida, quien emitió el certificado, validez, ... Sin embargo no nos asegura que sea 100% segura, ya que un ciberdelincuente puede crear una página con un certificado digital gratuito.

Como seguridad, se exige que los certificados sean expedidos por sitios autorizados de confianza.

Para asegurarnos, deberíamos utilizar urls con https y certificado digital, verifiquemos el certificado de que pertenece a la empresa que corresponda,

6. Conocimiento avanzado sobre el proceso de reporte y comunicación de ciberincidentes.

   Las empresas públicas o empresas privadas están obligadas por regulaciones específicas a informar sobre ciberincidentes, deben notificar aquellos incidentes en ciberseguridad que se ajusten a criterios de peligrosidad, impacto, alcance.

   En lo que respecta a los ciudadanos y empresas que no se encuentran dentro del ámbito de protección de infraestructuras críticas del sector público o de las regulaciones específicas mencionadas, la notificación de incidentes es opcional.

Sistema de ventanilla única: Se refiere a una plataforma o mecanismo centralizado que permite a las organizaciones y autoridades informar, gestionar y coordinar la respuesta a ciberincidentes.

Estos sistemas están diseñados para simplificar la notificación y el manejo de incidentes de ciberseguridad, promoviendo una respuesta rápida y coordinada frente a amenazas cibernéticas.

Carácterísticas y beneficios del sistema de ventanilla única:

1. Centralización: Permite a las organizaciones o usuarios reportar incidentes de ciberseguridad a una única entidad o plataforma, evitando la dispersión de información.
2. Notificación rápida: Facilita la notificación inmediata de incidentes, lo que es esencial para una respuesta eficaz.
3. Coordinación: Ayuda a coordinar la respuesta entre diversas partes interesadas, como organizaciones afectadas, agencias gubernamentales y proveedores de servicios de seguridad.
4. Seguimiento: Proporciona un seguimiento y registro detallado de los incidentes, lo que es esencial para el análisis posterior y para identificar tendencias de ciberseguridad.
5. Intercambio de información: Facilita el intercambio seguro de información relevante sobre amenazas y vulnerabilidades entre organizaciones.
6. Cumplimiento normativo: Puede proporcionar recursos, directrices y asesoramiento para ayudar a las organizaciones a responder adecuadamente a los incidentes.
7. Capacitación y orientación:

¿Si he sufrido un incidente a quien debo notificarlo?

Al Centro de Respuesta a Incidentes de Seguridad de referencia para los ciudadanos y entidades de derecho privado en España. Incibe (Agencia Nacional encargada de la Ciberseguridad en España) y opera el Centro de Respuesta a Incidentes de Seguridad e Industria (CERTSI), que se dedica a la gestión de ciberincidentes y la coordinación de respuestas en el ámbito nacional.

Guia Nacional de Notificación y gestión de ciberincidentes. https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_nacional_notificacion_gestion_ciberincidentes.pdf

UNIDAD 2

CIBERAMENAZAS TÉCNICAS DE DEFENSA

2.1 Conocimiento de los incidentes de seguridad

(robo, filtrado y secuestro de la información) y sus características.

1. Incidentes de seguridad

   Para proteger la información sensible y los sistemas informáticos, hay que comprender y aplicar técnicas de ciberdefensa sobre las ciberamenazas

Un incidente de seguridad es un evento o serie de eventos inesperados o no deseados, que tienen una probabilidad significativa de comprometer las operaciones del negocio; provocando una pérdida o uso indebido de información, interrupción parcial o total de los sistemas, siendo los mas comunes, la infección por malware, phising, etc

2. Tipos y clasificación

   TIPOS Incidentes de ciberseguridad:

   1. vinculados a la información

      Este tipo de incidentes incurren en la pérdida de información sensible para el funcionamiento de una empresa, así como el espionaje y robo de la identidad.

   2. vinculados a la infraestructura computacional.

      En esta ocasión se ve comprometida la operatividad de la empresa por la intrusión de malware, alteraciones en la red, fallas en los servidores, secuestro de datos y equipos entre otros.

   Clasificación según su contenido:

   1. Contenido abusivo: Son los que conocemos como spam, ya que tienen información ofensiva o no deseada que se torna molestosa.
   2. Contenido malicioso: básicamente son malware creados para infiltrarse en los sistemas operativos sin que los usuarios se den cuenta, dañándolos o comprometiendo la información que estos manejan. Dentro de estos tenemos los virus, gusanos, troyanos, spyware y ransonware.
   3. Obtención de información: en esta categoría tenemos los escaneos y el phishing, éste último se vale de técnicas de ingeniería social para persuadir a los usuarios y obtener datos confidenciales.
   4. Acceso no autorizado o intrusión: este tipo de incidentes se basan en el acceso a cuentas que manejan información crítica o ejecución de códigos maliciosos como ataques de día cero.
   5. Disponibilidad: son los ataques que bloquean el acceso a los servicios por parte de los usuarios, como por ejemplo tenemos los ataques DoS que se encargan de saturar sitios webs.
   6. Seguridad/Confidencialidad de la información: modalidad de ataque que compromete el acceso y modificación a la información.
   7. Fraude: problemas vinculados al uso no autorizado de información, phishing y robo de credenciales.
   8. Vulnerabilidad: ataques llevados a cabo aprovechando puntos débiles en los sistemas.

3. Tipos de ataques

   1. Malware: Acrónimo del inglés **mal**icius soft**ware**, por ello llamado también software malicioso y cuya traducción literal es código malicioso. Se infiltra en los sistemas para dañar o robar datos e información. Ejecutan acciones no deseadas en un sistema informático.

      Su principal diferencia es en la manera en que se propaga:

      1. infeciosos mas reconocidos:

         1. gusanos: Programa que se duplica a si mismo con la intención de dañar a una red en concreto, pasando de ordenador en ordenador. El gusano no necesita de un usuario para ser ejecutado, mientras que el virus si.

Objetivo: Dañar e infectar a la mayor cantidad de usuarios posible.

2. virus: Programa que tiene que ser ejecutado por otra persona para que pueda ponerse en funcionamiento. Estos pueden tener un payload o conjunto de datos transmitidos, que genera acciones maliciosas.

   Objetivo: Infectar software dentro del ordenador infectado.

   Tipos de virus:

   - De sector de arranque: se encargan de modificar el arranque del ordenador. Lo realizan cambiando el arranque original por una versión propia, para que al iniciar sesión, ésta lo haga con la versión manipulada e infectada.
   - De programa ejecutable: Se trata del virus más peligroso, es capaz de infectar archivos como .com, .exe,.. tiene la capacidad de dejar el ordenador inutilizable.

     Se puede ubicar o no en la memoria: desde la memoria puede controlar el sistema entero en el momento que lo precise y, desde fuera, sólo pueden ser ejecutados al iniciar el programa en concreto.
   - De correo electrónico: Se transmite de manera adjunta al correo electrónico. En el momento en el que esté activado puede suponer unos riesgos muy significativos dentro del sistema.
   - Residente en memoria: Se encuentran alojados en la memoria RAM del ordenador. Objetivo: es infectar los ficheros y programas justo cuando estos empiezan a ser ejecutados, hasta el momento en que se apaga el ordenador. Una de sus características principales es que sigue las pautas de la persona que lo desarrolló.

2. Oculto: El ocultamiento es necesario para llevarse a cabo. Los mas conocidos son:

   1. Rootkits: Programa que se encarga de modificar el sistema operativo del ordenador, de forma que el malware pueda mantenerse oculto de cara al usuario. Mantiene su presencia oculta, para que los administradores no puedan saber que el sistema ha sido manipulado e infectado.

      Ejemplo: Sony BMG Music Entertaiment incluyó el software Extended Copy Protection (XCP) y MediaMax CD-3 en el programa de protección de copias sin que nadie lo supiese, no podía ser visto por antivirus ni antispyware. Éste enviaba información sobre el cliente, abrió la puerta a otros malware. No se podía eliminar , pues dañaba al SO.

   2. Troyanos: En principio parece inofensivo. Capaz de borrar archivos o instalar programas dañinos. Puede ser confundido con un virus, pero mientras que el virus trata de dañar, el troyano puede, simplemente, conseguir hacerse con el control del ordenador sin ser descubierto y sin tener por qué necesariamente generar daños.

   3. Backdoors: "Puertas traseras", trata de romper con los procesos habituales de autenticación, para mejorar el acceso al atacante.

      Los ciberdelincuentes que utilizan este sistema de puertas traseras son denominados como crackers. Las instalan intentando pasar desapercibidos ante una inspección y así tener el control del equipo infectado. Este concepto de puerta trasera es muy similar , en términos de funcionabilidad, al utilizado

por muchos sistemas de administración y distribuidos por desarrolladores legítimos.

4. Drive-by download: Descarga involuntaria de software de ordenador que proviene de internet:

   Autorizada por una persona que no conoce las consecuencias.

   Descargas realizadas sin el conocimiento de estar siendo realizadas.

   Puede darse visitando un sitio web, haciendo click sobre una ventana emergente, en un correo electrónico.

   En todos estos casos el propietario de los elementos puede decir que el usuario consintió la descarga al acceder o hacer click, aunque fuera de manera inconsciente al haber autorizado la descarga.

3. Para obtener beneficios: Puede dar al usuario una serie de beneficios como su utilización como una fuente de ingresos, se puede dar con las técnicas:

   - Mostrar publicidad con programas:

     - Spyware: Objetivo: Controlar la actividad, en páginas webs o emails de los usuarios, y con ello, poder mandarla a agencias de publicidad a través de la técnica conocida como spam.

       El usuario no es consciente de que se está recopilando información acerca de él.

       Suelen ser instalados en forma de troyanos, mediante cookies o con las barras de herramientas de los navegadores.

       Cabe destacar que los que llevan a cabo el spyware se presentan en todo momento como empresas de publicidad, lo que les hace actuar de forma legal, aunque el usuario no sea consciente de lo que está aceptando.

     - Adware: Estos programas muestran publicidad de forma intrusiva a los usuarios para que esto produzca un beneficio. Se suele utilizar la técnica de pop-up o ventanas emergentes, que genera una sensación muy molesta

       Visto en un Video: La solución Bloqueadores de publicidad, su funcionamiento es analizar los sitios webs en busca de códigos de anuncios y evitan que puedan cargarse en un navegador. Se trata de software que se instala en los navegadores, de forma gratuita, los beneficios de un bloqueo de publicidad son varios:

       - los contenidos se cargan más rápidamente.
       - se desperdicia menos recursos de nuestro equipo.
       - se visualiza de forma más limpia el contenido de la página web.
       - Además se tiene mayor privacidad, por que se excluyen los sistemas de creación y seguimiento de perfiles de usuarios de la web.
       - Menor probabilidad de infección

       Aunque lo ideal es evitar las webs con demasiada publicidad, pero si vamos a entrar en conveniente utilizar un bloqueador de publicidad, esto ayuda a evitar los molestos banners.

        - Hijacking: Se dedican a realizar cambios dentro de las configuraciones del navegador web en cuestión. Modificar la página de inicio, redireccionar los resultados de los buscadores hacia los anuncios que ellos deseen , que suelen ser anuncios de pago.
    - Suplantación de identidad: **Phishing**: Obtener información privada de forma ilegal. Hacerse pasar por alguien de confianza, mediante correos electrónicos, sistemas de mensajería o llamadas de teléfono. Es una técnica no presencial.

      Es una de las estafas más comunes en internet. Ej: recibes un email de tu banco para pedir datos personales,... o una confirmación de una tienda online a través de un enlace y si clickeas sobre él, éste instalará un troyano que instalará un capturador de escritura, este capturador guardará todo lo que escribas con tu teclado, incluyendo usuarios y contraseñas. El enlace puede llevarte tambien a una página web falsa y pedirte introducir tus datos personales, ésta página falsa tendrá una apariencia prácticamente igual a la verdadera.

      Consejos para evitar el phishing:

      1. Las empresas no tienen costumbre de enviar correos pidiendo información personal, o financiera. Llama a la empresa para verificar si son ellos.
      2. No pulses en un enlace que te pida información confidencial o de pagos.
      3. verifica la dirección, normalmente se asemeja a la original. Utilizan normalmente un cero en lugar de una O, y un 1 en lugar de una l. Utilizar el logo de la web original también es muy común
      4. No utilizar la misma contraseña del banco para otros sitios web.
4. Para robar información: Los malwere, se utiliza sobre todo para robar información personal o bancaria
    - Keyloggers:

      ¿Que Hace? Analizan y registran las pulsaciones sobre el teclado, de forma que esta información pueda ser enviada a través de internet.

      ¿Para que se usa? Es muy común frente a situaciones en las que el usuario introduce contraseñas o números de tarjeta de crédito. De esta forma puede manipular e incluso realizar pagos de forma fácil sin el consentimiento del usuario.
    - Stealers:

      ¿Que Hace? Roba la información que se encuentra guardada previamente en el equipo.

      ¿Para que se usa? En aquellas ocasiones en las que el atacante quiere robar información privada del usuario y utilizarla en su propio beneficio sin su consentimiento.
    - Dialers:

      ¿Que Hace? Se trata de un programa capaz de realizar llamadas con un coste adicional gracias al módem del ordenador.

      ¿Para que se usa? Se utiliza para obtener dinero de forma fraudulenta por medio de llamadas realizadas a un número de teléfono del alto coste.
    - Ransonware:

¿Que hace? Se trata de programas que bloquean el ordenador, el cual no puede ser desbloqueado hasta que se consigue su objetivo.

¿Para que se usa? Son programas que cifran los archivos mas importantes, con la intención de que éstos no puedan ser autorizados por nadie. Acto seguido, solicitan una especie de "rescate" para obtener la contraseña que le permita recuperar los archivos.

Ejemplo: WannaCry. En Septiembre de 2018, el departamento de justicia de Estados Unidos inculpó al norcoreano Park Jin Hyok der ser el creador de WannaCry y haber acometido el ataque informático de alcance mundial en 2017. Afectó a 150 paises, en hospitales, renault, nissan,... Pedía pagar bitcoins para poder regresar a antes del ataque, atacó a ordenadores de microsoft.

2. Ataques distribuidos DoS: Los ataques distribuidos también conocidos como de Denegación de Servicio (DoS) o Denegación de Servicio Distribuida (DDoS), se trata de una situación en la que el usuario y/o empresa se encuentra con un acceso denegado a unos servicios o recursos a los que suele poder acceder con normalidad.

   - Ataques internos: En este tipo de ataque, cabe la posibilidad de que la motivación sea o bien casual o bien intencionada.
   - Ataques externos: Los ataques en este caso se producen de forma motivada por una persona ajena a la organización con fines concretos.

   Al servidor se le vuelve completamente imposible poder procesar todos los paquetes de información que empieza a recibir. Debido a una saturación de ancho de banda del servidor, debido al agotamiento de los recursos del sistema, lo que no permite que esta pueda responder de forma natural al tráfico de los mismos.

   Puesta en marcha de un ataque DDos:

   - Multitud de conexiones simultáneas
   - Enviar paquetes alterados
   - Modificar los paquetes: Poniendo como IP de origen una IP falsa, de forma que no se pueda saber quien es el atacante.
   - Utilizar Botnets, ordenadores infectados por un troyano. Esto significa que las personas que participarían en el ataque no sabrían lo que están haciendo.

   Este tipo de ataque consisten en ordenadores zombies, atacan a un solo objetivo para causar la denegación de servicio, esto crea una multitud de flujo de mensajes en el ordenador de la victima para que se sobrecargue y de esta forma se cierre o vaya más lento, como resultado, se le niega el servicio a los verdaderos usuarios.

3. Amenazas APT: Avanced Persistant Threat, son procesos dirigidos específicamente a conseguir un objetivo concreto. Normalmente, tratan de robar información a corporaciones o empresas, auqnue pueden dirigirse a una persona o colectivo determinado.

   Requieren un largo periodo de preparación por parte del atacante.

   Requieren una gran motivación

   También, una importante inversión económica para poder ejecutarse.

   Los beneficios son exponencialmente proporcionales al tiempo e inversión que realizan.

Es muy dificil protegerse de este tipo de ataques, será necesario desplegar medidas de "defensa en profundidad" combinadas con estrategias de defensa temprana y políticas eficaces de seguridad.

2.2 Capacidad para la implementación de las estrategias de protección contra los ciberataques

1. **Certificados SSL/TLS**: Protocolos criptográficos, sirven para autenticar y cifrar información que se maneja entre los distintos servidores de la red.

   Ofrecen privacidad e integridad dentro de la comunicación, lo que quiere decir que la información no podrá ser ni interceptada, ni modificada por elementos que no estén autorizados.

   SSL (Secure Socket Layer o Capa de Puertos Seguros) es el predecesor del TLS (Transport Layer Security o Seguridad de la capa de Transporte)

   Protocolo SSL Lograba que la información viajara segura cuando:

   - Introducíamos datos bancarios
   - Enviábamos contraseñas.
   - Enviábamos información privada o confidencial.

   Protocolo TLS Surgió como una manera de actualizar el protocolo anterior y mejoró aspectos como:

   - Su seguridad y fiablilidad
   - Su privacidad en cuanto a conexiones.
   - Su velocidad y rendimiento.

   Diferencias: Mientras que SSL se encuentra en la capa de sesión del modelo OSI, TLS se ubica en la capa de transporte. Con SSL se utilizaban certificados y algoritmos de cifrado poco seguros (tanto simétricos como asimétricos), por eso hoy en día lo normal es que las conexiones utilicen TLS.

2. **Protocolo HTTPS**: Protocolo seguro de transmisión de hipertexto, es la versión segura del protocolo http. Los sitios web https, cuentan con un certificado SSL/TLS instalado en el servidor, este certificado cifra los datos transmitidos desde el navegador, hasta el servidor, de esta forma, la información que transmite el sitio web, no podrá ser usada por alguien que haya conseguido interceptar esa transferencia. Lo único que conseguirá son datos cifrados, imposibles de descifrar.

   Esta seguridad es necesaria, por que muchas veces transmitimos datos sensibles por la red, datos personales, información financiera, usuarios y claves, y puede ocurrir que terceros malintencionados o cualquier tipo de intruso ingiera en la transferencia de datos.

   Otra cosa que podemos hacer con SSL es vincular tu identidad de marca con su presencia web, de manera que los visitantes vean que la web está controlada por tu empresa y no por impostores. Si queremos saber si un sitio web está protegido con este protocolo, basta con fijarnos en la barra de direcciones que nos debe mostrar https y junto a este un icono de un candado que indica protección, además cualquiera puede utilizarlo, puesto que no requiere

la instalación de ningún software adicional, como empresa es una muy buena forma de inspirar confianza y como usuario de sentirte protegido.

Este protocolo https forma parte de la capa de aplicación del Modelo OSI "Hyper Text Protocol Secure" o "Protocolo Seguro de Transferencia de hipertexto".

Cuando un sitio web está protegido tiene el protocolo http + SSL/TLS= https

2.3 Capacidades para aplicar técnicas de defensa en el ciber-entorno

1. Robo de credenciales
    1. El atacante comienza con una ingeniería social para fingir ser un empleado legítimo de la empresa. Esto puede incluir el envío de correos electrónicos o el uso de cualquier otra técnica para engañar a los usuarios.
    2. El atacante crea una página web falsa mostrando una página de inicio de sesión. Esta página puede ser muy similar a la página web legítima de la empresa.
    3. El atacante envía un enlace a la página web falsa a los usuarios. Esto puede incluir el envío de correos electrónicos, mensajes de texto, anuncios en línea, etc.
    4. Cuando el usuario accede a la página web falsa, ingresa sus credenciales de usuario.
    5. El atacante roba las credenciales de usuario y puede usarlas para acceder a la cuenta real del usuario.
    6. El atacante ahora puede acceder a la información de la cuenta, como archivos, correos electrónicos, información personal, etc.

Formas de almacenar la información de credenciales robadas

- Bases de datos: Los ciberdelincuentes pueden crear bases de datos para almacenar grandes cantidades de información de credenciales robadas. Estas bases de datos pueden ser accedidas a través de la red y pueden ser vendidas o utilizadas por ciberdelincuentes para acceder a cuentas y realizar actividades ilegales.
- Servidores de descarga: Los ciberdelincuentes pueden almacenar y distribuir la información de creadenciales robadas. Los usuarios pueden acceder a estos servidores a través de la red y descargar información de credenciales a cambio de un pago.
- Redes de Botnets: Los ciberdelincuentes también pueden utilizar redes de botnets (un conjunto de terminales controladas por un atacante) para almacenar y distribuir la información de credenciales robadas. Estas redes suelen estar ocultas y pueden ser difíciles de detectar.

2. Password en Windows: En Windows, las contraseñas son utilizadas para proteger la privacidad y seguridad de los usuarios. Las contraseñas se utilizan para proteger el acceso a la cuenta de usuario y a los archivos y carpetas privados del usuario.

   Para establecer o cambiar las contraseña de una cuenta de Usuario en Windows puede:

   1. Hacer click en el botón de Inicio de Windows y selecciona "Configuración"
   2. Selecciona "Cuentas"
   3. A continuación, haz click sobre "Familia y otras personas" y luego seleccione la cuenta de usuario para la que desea establecer o cambiar la contraseña.
   4. Te ofrecerá la opción de cambiar contraseña. Haz click sobre ella para realizar cambios.
   5. Por último, sigue las instrucciones y establece o cambia la contraseña.

   Debemos asegurarnos que la contraseña debe ser:

   - Longitud mínima de 8 caracteres.
   - Que combine mayúsculas, minúsculas, símbolos y números.

   No se debe:

   - Utilizar palabras sencillas en cualquier idioma, nombres propios, lugares, fechas de nacimiento,..
   - Tampoco debemos usar claves formadas únicamente a partir de la concatenación de varios elementos. Por ejemplo Jesus1980 (nombre + fecha nacimiento)

   Las credenciales en caché son información de inicio de sesión que se almacena temporalmente en el equipo para facilitar el acceso a ciertos servicios o aplicaciones. Por ejemplo cuando inicias sesión en tu cuenta de correo o en una red social, es posible que se te pida que ingreses tus credenciales (usuario y contraseña)

   Si eliges la opción de "recordar contraseña", esa información se almacena en caché en tu equipo, lo que significa que la próxima vez que intentes acceder a ese servicio no tendrás que volver a ingresar tus credenciales.

   Las credenciales en caché pueden ser útiles para facilitar el acceso a servicios que utilizamos con frecuencia, pero también pueden presentar riesgos para la seguridad. Si otra persona tiene acceso físico a tu equipo, podría intentar acceder a servicios o aplicaciones utilizando tus credenciales en caché. Además, si tu equipo se encuentra con un malware, es posible que ese malware intente acceder a tus credenciales en caché, para utilizarlas de manera malintencionada.

3. Encriptar, codificar, cifrar y uso de certificado

   Para evitar el robo o acceso a información sensible, podemos ocultar los datos sensibles. Existen diferentes métodos :

   - encriptado o cifrado que funciona alterando los símbolos que componen el mensaje. La información se convierte en letras, números y símbolos sin sentido que sólo el propietario podrá descifrar.
   - Codificación: con este método alteramos la semántica del mensaje, lo que está relacionado con el significado del mensaje.

Éstos métodos también nos protegerán de cara a un robo o pérdida del dispositivo, ya que un caso así nadie podrá ver nuestra información.

Por último recomendamos el uso de certificados de seguridad. Se trata de medidas para cifrar nuestros datos entre nuestro dispositivo y una página web. Son realmente importantes para mantener seguros nuestros datos a la hora de navegar por internet.

¿Qué puedes hacer para proteger tus equipos y mantener tus credenciales seguras?

1. Contraseñas seguras: Asegurate que sean difíciles de adivinar y que no utilices en mas de un servicio o aplicación.
2. Autenticación de dos factores: Muchos servicios ofrecen la opción de autenticación de dos factores, lo que significa que además de ingresar tu contraseña, tendrás que proporcionar otro tipo de información para poder acceder al servicio. Ej: un código que se envía a tu teléfono móvil o una huella digital.
3. No compartas tus credenciales: nunca compartas con otras personas, incluso amigos o familiares.
4. Usa software de seguridad: Instala un software para proteger tu equipo de virus y otros tipos de malware.
5. Contraseñas diferentes para cada servicio: Aunque puede ser tentador utilizar la misma contraseña para todos los servicios, esto puede ser peligroso, en caso de que uno de ellos sea hackeado. Utiliza contraseñas diferentes para cada servicio.

   No almacenes tus credenciales en caché en sitios públicos: Por ejemplo: bibliotecas. Acuérdate de no almacenar y cerrar sesión en todos los servicios y aplicaciones antes de salir del equipo.
6. Activa la encriptación de disco: Ésta protege la información almacenada en tu equipo mediante el uso de una clave de cifrado. ¿Por qué? Si tu equipo es robado o extraviado, la información no podrá ser accedida sin la clave de cifrado.
7. Configura la autenticación de inicio de sesión: Muchos sistemas operativos permiten configurar la autenticación de inicio de sesión, lo que significa que, además de ingresar tu contraseña, tendrás que proporcionar otra forma de autenticación para acceder al sistema. Esto puede ser por ejemplo una huella digital o un código de autenticación enviado a tu teléfono móvil.

4. Motivaciones de los ciberdelincuentes

Hay multitud de datos acumulados en la red y en nuestros dispositivos que pueden ser atacados por ciberdelincuentes. Las razones de éstos para realizar ataques de denegación de servicio (DoS) o distribuida (DDoS) pueden ser múltiples.

Delitos de extorsión:

La extorsión en la red, también conocida como ciberextorsión, es un delito en el que un individuo o grupo de individuos exigen a otra persona o empresa un pago o una acción específica a cambio de no realizar algún tipo de acción dañina o de no revelar información sensible. Algunos ejemplos de situaciones de extorsión si no se procede al pago pueden ser:

- **Amenazas de publicación de información privada**. Los ciberdelincuentes pueden amenazar con publicar información privada o confidencial de un individuo o empresa en línea, a menos que se pague un rescate.

- **Amenazas de sabotaje**: Los ciberdelincuentes también pueden amenazar con sabotear un sistema o servicio en línea de una empresa, a menos que se pague una suma de dinero.

Vandalismo:

Estos ataques pueden ser realizados por ciberdelincuentes por diversas razones como:

- **Placer de causar daño:** Algunos ciberdelincuentes pueden realizar ataques DoS o DDoS simplemente por el placer de causar daño o interrumpir el funcionamiento de un sitio web o servicio en línea.
- **Competencia desleal:** Los ataques DoS o DDoS también pueden ser utilizados por empresas o individuos para tratar de debilitar la competencia.

Distracción:

En algunos casos, los ataques DoS o DDoS pueden ser utilizados como una táctica para distraer la atención de un objetivo más importante, mientras se lleva a cabo otra actividad ilegal.

Competencia desleal:

Los ataques DoS o DDoS también pueden ser utilizados por empresas o individuos para tratar de desacreditar o debilitar a la competencia.

5. Las víctimas

Los ataques de denegación de servicio (DoS) o distribuidos (DDoS) pueden afectar a cualquier tipo de organización o individuo que tenga un sitio web o un servicio en línea.

Empresas: A menudo son objeto de estos ataques debido a su dependencia de Internet y de los servicios en línea para realizar sus operaciones cotidianas. Estos ataques pueden tener un impacto significativo en la productividad y en los ingresos de la empresa.

Instituciones gubernamentales: Estos ataques pueden ir dirigidos a agencias de aplicación de la ley, departamentos de servicios públicos y servicios de emergencia. Estos ataques pueden interrumpir el funcionamiento de servicios esenciales y poner en peligro la seguridad de la población.

Organizaciones sin fines de lucro: Sus sitios web y servicios en línea son esenciales para la comunicación y el apoyo a sus causas.

Individuos: Especialmente si tienen un sitio web personal o utilizan un servicio en línea para realizar actividades importantes, como la banca en línea.

Para tener medidas de seguridad y proteger nuestro sistema de ataques DoS y DDoS, tenemos que informar a las autoridades y a un experto en ciberseguridad.

6. Casos reales

1. Caso DYN: Un ejemplo famoso de un ataque de denegación de servicio (DoS) o distribuido (DDoS) es el ataque a la red de Dyn en octubre de 2016. Dyn es un proveedor de servicios DNS (Domain Name System) que brindaba servicios de resolución de nombres de dominio a muchas de las principales empresas de internet, incluyendo Amazon, Netflix y Twitter.

   El ataque fue llevado a cabo con el malware Mirai, que se propagó a través de dispositivos conectados a Internet, como cámaras de vigilancia y routers, y los convirtió en "bots" que podían ser controlados y utilizados para enviar tráfico falso a un objetivo específico. Fue impactante debido a la gran cantidad de tráfico que se generó y a la cantidad de empresas que dependian de Dyn para el funcionamiento de sus servicios en línea. El ataque tuvo un impacto significativo en el rendimiento de muchos servicios en línea y fue un recordatorio del poder de los ataques DDoS y de la importancia de tomar medidas de seguridad y mitigación de riesgos.

2. Caso Cloudflare: Tuvo lugar en marzo de 2021 contra el proveedor de servicios de cloud gaming, Cloudflare. El ataque fue llevado a cabo utilizando una técnica conocida como "amplificación de NTP", que consiste en enviar una solicitud falsa a un servidor de hora de red para obtener una respuesta mucho mayor de lo esperado. El ataque generó una gran cantidad de tráfico y causó problemas de rendimiento y latencia en los servicios de Cloudflare durante varias horas.

   Las empresas deben tener planes de contingencia en lugar y estar preparadas para responder de manera efectiva a los ataques DDoS para minimizar el impacto en sus servicios y en sus clientes.

7. Medidas de seguridad y mitigación de riesgos

   1. Utilizar Firewalls y sistemas de detección de intrusiones (IDS)

      Los firewalls son sistemas de sistemas de seguridad que protegen una red permitiendo o bloqueando el tráfico de red basándose en reglas predefinidas. Los firewalls pueden ayudar a proteger contra ataques DoS o DDoS bloqueando el tráfico sospechoso. Los sistemas de detección de intrusiones (IDS) son herramientas de seguridad que monitorizan la actividad en una red y alertan a los administradores de sistemas de posibles ataques o actividades sospechosas en curso.

   2. Usar un servicio de protección (DDoS)

      Los servicios de protección DDos se encargan de filtrar el tráfico de Internet y bloquear el tráfico sospechoso antes de que llegue al servidor. Esto puede ayudar a mitigar los efectos de un ataque DDos. Los servicios de protección DDoS pueden ser contratados a través de un proveedor de servicios de seguridad en línea.

   3. Utilizar soluciones de mitigación de ataques DoS o DDoS.

      Las soluciones de mitigación de ataques DoS o DDos son herramientas que ayudan a proteger contra estos ataques. Algunas soluciones comunes incluyen la reescritura de cabeceras de paquete, que modifica el tráfico entrante para hacerlo menos vulnerable a los ataques DoS o DDoS, y la distribución geográfica de servidores, que dispersa el tráfico entre varios servidores ubicados en diferentes partes del mundo para disminuir la efectividad de un ataque DDoS.

4. Implementar medidas de seguridad en la red.

   Es importante implementar medidas de seguridad en red, como el uso de contraseñas seguras y la actualización regular de software y sistemas operativos, para protegerse contra los ataques DoS o DDoS. También es importante asegurarse de que la red esté bien configurada y que se estén utilizando medidas de seguridad adecuadas, como el cortafuegos y la autenticación de dos factores.

5. Mantener copias de seguridad y planes de contingencia.

   Es importante tener copias de seguridad de todos los datos importantes y tener planes de contingencia en caso de que se produzca un ataque DoS o DDoS. Esto puede a ayudar a minimizar el tiempo de inactividad y a mantener el funcionamiento de la empresa durante y después del ataque. Los planes de contingencia deben incluir una lista de pasos a seguir en caso de un ataque, así como información sobre como comunicarse con los equipos de respuesta a incidentes y como acceder a las copias de seguridad.

6. Utilizar redireccionamiento de tráfico.

   En caso de un ataque DDoS masivo, es posible que sea necesario redirigir el tráfico a otro servidor o a una red protegida para mitigar el impacto del ataque. Esto se puede hacer mediante la configuración de reglas de enrutamiento de tráfico específicas en el firewall o en el sistema de enrutamiento de la red.

7. Utilizar herramientas de monitoreo de tráfico.

   Las herramientas de monitoreo de tráfico, como los sistemas de monitoreo de rendimiento (PM) y los sistemas de monitoreo de red (NMS), puden ayudar a detectar ataques DoS o DDoS en curso y proporcionar información valiosa para la resolución de problemas y la toma de decisiones.

8. Participar en la comunidad de seguridad.

   Es importante participar en la comunidad de seguridad y estar al tanto de las últimas tendencias y amenazas en términos de ataques DoS o DDoS. Asistir a conferencias y eventos de seguridad y participar en foros en línea puede ayudar a mantenerse informado y a obtener consejos y recomendaciones de expertos en la materia.

8. Prepárate

   Siempre existe el riesgo de sufrir un ataque DoS o DDoS. Por lo tanto es importante estar preparado y tener planes de contingencia para minimizar el impacto de un ataque y mantener el funcionamiento de la empresa.

   Plan de Contingencia en lugar:

   Es importante tener un plan de contingencia en lugar para minimizar el impacto de un ataque DoS o DDos y mantener el funcionamiento de la empresa. El plan de contingencia debe incluir una lista de pasos a seguir en caso de un ataque, así cómo comunicarse con los equipos de respuesta de incidentes y cómo acceder a las copias de seguridad.

Tener copias de seguridad de todos los datos importantes:

Es fundamental tener copias de seguridad de todos los datos importantes para minimizar la pérdida en caso de un ataque DoS o DDoS. Las copias de seguridad deben ser realizadas regularmente y deben almacenarse en un lugar seguro y separado del sistema principal.

Monitorear la actividad en la red:

Utilizar herramientas de monitoreo de tráfico, cómo los sistemas de monitoreo de red (NMS), puede ayudar a detectar ataques DoS o DDoS en curso y proporcionar información valiosa para la resolución de problemas y la toma de decisiones.

Comunicarse con los equipos de respuesta a incidentes:

En caso de un ataque DoS o DDoS, es importante comunicarse con los equipos de respuesta a incidentes y seguir sus instrucciones para minimizar el impacto del ataque.

2.4 Capacidad para minimizar los daños causados por los posibles ciberdelicuentes.

1. ¿Cómo responder ante un incidente de ciberseguridad?

   El protocolo a seguir en caso de un incidente de ciberseguridad es el siguiente:

   Limitación del daño y reducción de riesgos: para reducir el impacto negativo del incidente se debe hacer una desconexión de los equipos de la red y reiniciar los sistemas, sin embargo hay empresas donde no se puede suspender completamente la operatividad, de modo que se puede hacer por partes. También se debe clasificar los datos y reforzar la seguridad de la información sensible, a fin de reducir riesgos de un daño mayor.

   Recuperar el control de los sistemas: una vez reiniciados los equipos se procede a la instalación de las instalación de las copias de seguridad para restablecer el funcionamiento. Es importante determinar cuándo se produjo el incidente para instalar la copia de seguridad previa a este, ya que las otras pueden estar dañadas.

   Corregir los fallos de seguridad y vulnerabilidades que permitieron el incidente.

   Antivirus y aplicaciones Antimalware:

   ¿Se te han borrado archivos sin saber por qué? ¿Han utilizado tus datos en el envío de emails sin tu autorización?

   Los virus afectan a 1 millón de ordenadores cada año. La primera norma en ciberseguridad es clara, usar un antivirus junto con aplicaciones anti-malware.

   Los virus son programas informáticos que ejecutamos de manera involuntaria, permitiendo que se alojen en la memoria de nuestro equipo. De esta forma pasan a infectar a otros archivos que de pronto dejan de funcionar.

   El antivirus detecta cuando un programa de este tipo se descarga en nuestro sistema y nos avisa anunciándonos dónde está alojado y su futura eliminación o envío a cuarentena.

Entre los principales daños que pueden causar estos programas está la pérdida de rendimiento del equipo, el borrado de archivos, la alteración de datos, la exposición de información confidencial a personas no autorizadas e incluso el impedimento de arrancar el sistema operativo. Lo mejor es prevenir esta situación e instalar un antivirus en nuestro equipo junto con aplicaciones antimalware en nuestros dispositivos móviles. Pueden ser gratuitos o de pago, todo dependerá del grado de seguridad que necesitemos y de las características que más nos convengan. Existen muchas páginas donde podremos ver y elegir el que más nos convenga. Normalmente los antivirus monitorizan actividades de

virus en tiempo real y hacen verificaciones periódicas. También se pueden configurar análisis automáticos para que busquen y anulen los virus de nuestros equipos.

Teniendo en cuenta la cantidad de programas maliciosos o malware que se crean a diario, es aconsejable que actualicemos con frecuencia nuestro antivirus para que cuente con las últimas actualizaciones y no se vuelva obsoleto, ya que entonces no nos sirve de nada. La actualización puede ser configurada para que sea automática y así cada vez que haya un código nuevo, nuestro antivirus tenga las últimas herramientas para detectarlo. Hoy en día también hay antivirus online, que nos pueden ser útiles cuando, por ejemplo, utilizamos un ordenador de un cibercafé para trabajar en uno de nuestros proyectos. En este caso es aconsejable un antivirus online para que no dañe nuestros archivos. Estos verificadores online tienen la ventaja de que están siempre actualizados porque están hospedados en los servidores de las propias empresas que los mantienen.

En resumen buscaremos un antivirus bien gratuito o bien de pago, dependiendo de nuestra necesidad, y si vamos a trabajar en un ordenador que no es nuestro, buscaremos un verificador online para que nuestros archivos estén a salvo.

¿Qué es la criptografía?

Es el estudio y práctica de técnicas de seguridad y privacidad para comunicaciones y datos, con el objetivo de proteger la información de accesos no autorizados o cambios no autorizados.

Se utiliza para cifrar o codificar la información de tal manera que sólo las personas autorizadas pueden entenderla, mientras que los demás sólo ven información ilegible.

Es una forma de asegurar la confidencialidad de los datos.

USOS:

- Verificar la integridad de los datos
- Autenticar a los usuarios o dispositivos

Plan de recuperación antedesastres

Estrategia que se implementa para responder a los incidentes de seguridad informática que afectan la disponibilidad, confidencialidad o integridad de los datos o sistemas de una organización.

El objetivo principal del plan de recuperación ante desastres en ciberseguridad es minimizar el impacto de los incidentes de seguridad informática y restaurar la operación normal de los sistemas de información de la organización lo antes posible.

Medidas:

- Identificación: es importante realizar un análisis de riesgos para identificar amenazas y vulnerabilidades que podrían afectar la seguridad informática de organización.
- Definición de los procedimientos: una vez identificados los riesgos, es necesario definir los procedimientos y acciones a seguir para responder a los incidentes de seguridad informática. Estos procedimientos deben ser claros y estar disponibles para todos los empleados involucrados.
- Creación del equipo de respuesta: Se debe establecer un equipo de respuesta ante incidentes de seguridad informática, que cuente con la capacidad de tomar decisiones rápidas y efectivas en situaciones de emergencia.
- Pruebas y simulaciones: es importante realizar simulaciones y pruebas periódicas del plan de recuperación ante desastres para asegurarse de que está actualizado y funciona correctamente.
- Capacitación de los empleados: todos los empleados de la organización deben estar capacitados en cuanto a la importancia de la seguridad informática y los procedimientos de respuesta ante incidentes de seguridad.
- Evaluación y mejora continúa: es importante evaluar regularmente el plan de recuperación ante desastres y hacer mejoras en función de los resultados de las pruebas y simulaciones, así como de los incidentes de seguridad informática ocurridos en el pasado.

Unidad 3 Ciberseguridad. Lenguajes de programación

Conocimiento avanzado de los lenguajes de programación en ciberseguridad

1. Conocimiento del lenguaje común de los ciberriesgos

1. Que es un ciberriesgo

   Se refiere a la probabilidad de que ocurra un evento cibernético no deseado o un incidente de seguridad que pueda tener un impacto negativo tanto en particular como en una organización.

   Estos riesgos incluyen:

   - Pérdida de datos
   - Interrupción de servicios
   - Robo de información confidencial.
   - Exposición de vulnerabilidades

   Elementos ineludibles:

   - Hackers
   - Ingeniería social

Hacking es un término general utilizado para nombrar actividades destinadas a poner en peligro las computadoras y redes.

Son instrucciones indeseadas que comprometen la privacidad del titular y del usuario, irrumpiendo en un dispositivo, red o servidor con la intención de dañar propiedades contenidas en el equipo tales como: archivos, documentos, páginas web, etc.

El hacking también se aplica a actividades benignas, sin embargo, comunmente se relaciona con la intención maliciosa de explotar vulnerabilidades del sistema para beneficiar al perpetrador.

Las personas involucradas en el hacking se denominan hackers.

El hacking no requiere, necesariamente, buenas habilidades informáticas.

Los piratas informáticos también pueden utilizar ingeniería social para acceder a computadoras y sistemas. Este conjunto de tácticas son diseñadas para engañar a objetivos inocentes, para que éstos acaben ofreciendo sus datos a los hackers.

El hacking requiere algunas habilidades de TI (tecnología de la información), pero cualquiera puede acceder a la dark web y comprar las herramientas necesarias para lanzar un ataque o contratar a un hacker profesional para lanzar el ataque.

Motivaciones de los hackers:

- Ganancias financieras.
- Robo de información personal.
- Acceso a información confidencial.
- Deseo de eliminar sitios web.
- Idealismo y activismo político.

Si bien algunas formas de piratería son perfectamente legales, la mayoría no lo son y se consideran delitos penales.

Dependiendo de la gravedad del ataque, los hackers en los Estados Unidos pueden ser condenados desde unas pocas semanas hasta 15 años de prisión por delitos informáticos.

Tipos de Hackers: Según sus intenciones y según la legalidad de sus ataques

- Hacking de sombrero blanco: A menudo conocido como piratería ética, la piratería de sombrero blanco siempre se usa para siempre. En lugar de convertirse en el prodigio que traiciona el estereotipo que a menudo se ven en las películas, las grandes corporaciones suelen contratar a los piratas informáticos para que les ayuden a mejorar la seguridad identificando las vulnerabilidades del sistema. Los hackers éticos utilizan casi los mismos métodos que cualquier otro hacker, pero simplemente lo hacen con el permiso del propietario del sistema.
- Hacking de sombrero negro: el hacking de sombrero negro es lo opuesto al hacking de sombrero blanco, por lo que se llama inmoralidad. Los piratas detrás de un ataque de sombrero negro pueden estar motivados generalmente por ganancias personales o financieras. Debido a que no hay un permiso explícito de propietario para atacar el sistema, los correos electrónicos de phising o los sitios comprometidos se utilizan para descargar e instalar software malicioso en las

computadoras de las víctimas potenciales y de este modo robar información personal.

- Hacking de sombrero gris: El truco del sombrero gris está en algún lugar entre lo ético e inmoral. Los hackers de sombrero gris generalmente no se vuelven completamente maliciosos, pero algunos de sus movimientos pueden interpretarse como táles. Por ejemplo, podría entrar en una red sin el permiso del propietario para buscar vulnerabilidades. Después de eso, generalmente se comunican con el propietario y solicitan una pequeña tarifa para resolver el problema. Sin embargo, si el propietario rechaza la oferta, los piratas informáticos pueden compartir los hallazgos en línea y alentar a los pares poco éticos a explotar estas vulnerabilidades

2. Hackers

¿Quienes son los ciberdelincuentes y qué buscan?

Hacker: Solventar, paliar e informar sobre problemas encontrados en un sistema informático.

Ciberdelincuente: Sacar partido de dichos fallos.

Sus victimas potenciales son: grandes empresas, pymes , el ciudadano de a pie también es una víctima en potencia.

¿Qué motiva a un ciberdelincuente?

- Superación: superar retos u obstáculos.
- Beneficio económico: identificar vulnerabilidades para luego explotarlas
- Ideología: Lograr el mayor impacto posible de un mensaje ideológico
- Venganza: Dañar nuestra reputación o sacar beneficio a nuestra costa.

¿Cómo actúan los ciberdelincuentes?

Disponen de una gran variedad de programas informáticos. Sin embargo, el error humano es la puerta de entrada a la mayoría de los ciberataques. Utilizan la ingeniería social, para las técnicas de manipulación, para obtener la información de los propios usuarios.

1. Robos de credenciales: Roban nuestros datos para suplantar identidades, acceder a cuentas bancarias, redes sociales, etc. Utilizan métodos como los siguientes para obtener nuestras credenciales: Phishing, ataque por fuerza bruta, OSINT, Keyloggers.
2. Chantajes y extorsión: Consiguen información confidencial con la que tener el control sobre la persona afectada a través de los emails, las redes sociales o por medio de perfiles falsos con los que obtener la información que buscan. **Otro medio es mediante programas que incluyen virus o malware.**
3. Malware: Utilizan software maliciosos para conseguir el control total o parcial de nuestros dispositivos y obtener un beneficio a nuestra costa. Se sirven de los siguientes tipos de malware: Troyano, Gusano, Ransomware, Spyware, Rootkit, Adware.

4. Ataques de denegación de servicio: Solicitudes o peticiones que provocan algún fallo en un recurso o servicio hasta colapsarlo y dejarlo inaccesible. Para ello, pueden, por ejemplo, infectar nuestros equipos y controlarlos de forma remota. Botnets y redes zombies.

3. Ingeniería social.

   Es la forma no técnica de entrar en un sistema o red. Es el proceso de engañara los usuarios del sistema para que realicen acciones útiles para los piratas informáticos, como proporcionar información que puede ser utilizada para eludir o eludir los mecanismos de seguridad.

   Los piratas informáticos pueden usarla para atacar el elemento humano en el sistema y eludir las medidas técnicas de seguridad. Este método se puede utilizar para recopilar información antes o durante un ataque.

   Las empresas con procesos de autenticación, firewalls, redes privadas virtuales y software de monitoreo de redes siempre son vulnerables a ataques externos, por que **la ingeniería social no ataca directamente las medidas de seguridad.**

   El arte de la manipulación: La ingeniería social implica la **recopilación de información confidencial o el acceso indebido a los privilegios de extraños, con base en la construcción de relaciones de confianza inapropiadas.** Los piratas informáticos que son cotactados pareciendo ser parte de la organización son los más exitosos con los ataques de ingeniería social.

   Tipos de ataques:

   1. **Basados en personas.** Se refiere a la iteración entre persona y persona para obtener la información necesaria.
   2. **Basados en el cómputo.** Se refiere a tener los programas informáticos para intentar obtener la información deseada.

Técnicas de ingeniería social. ¿Cómo consiguen engañarnos?

- **Phishing**: Busca “pescar” víctimas. Generalmente se emplean correos electrónicos con archivos adjuntos infectados o links a páginas fraudulentas con el objetivo de tomar el control de sus equipos y robarles información confidencial.
- **Pretexting**: Base de cualquier ataque de ingeniería social. Consiste en elaborar un escenario / historia ficticia, donde el atacante tratará de que la víctima comparta información que, en circunstancias normales, no revelaría.
- **Sextorsión**: Chantaje donde amenazarán a la víctima con distribuir supuestamente contenido comprometido de ella a sus contactos (aunque no exista dicho contenido), si no accede a las peticiones del ciberdelincuente, generalmente a realizar un pago.
- **Baiting**: Emplea un cebo con software malicioso a la vista de sus víctimas para que ellos mismos infecten sus dispositivos.
- **Smishing**: Se trata de una variante del “phishing” pero que se difunde a través de SMS. Se pide al usuario que llame a un número de tarificación especial o que acceda a un enlace de una web falsa.
- **Vishing**: Llamadas telefónicas donde el atacante se hace pasar por una organización/persona de confianza para que la víctima revele información privada.

- **Shoulder Surfing**: Consiste en mirar por “encima del hombro”. Al atacante le basta con observar lo que escribe o tiene en pantalla otro usuario para obtener información muy útil.
- **Dumpster diving**: Se refiere al acto de “husmear en la basura”, para obtener documentos con información personal o financiera.
- **Quid pro quo**: Prometen un beneficio a cambio de información personal y suelen ser compensaciones en formato regalo (merchandising, dinero o acceso gratuito a programas de pago)
- **Redes Sociales**: Las técnicas de engaño más comunes a través de las redes sociales son mediante cupones descuento, juegos y concursos, donde crees que puedes ganar algo.

Ciclo de la ingeniería social: ¿Cómo preparan los ciberdelicuentes un ataque de ingeniería social?

- Investigación: El ciberdelincuente investiga a la víctima recogiendo información sobre ella de utilidad.

  PROTECCIÓN: Sé cuidadoso con la información que publicas y compartes en tus redes sociales así como en otros servicios online.

- Gancho: Se elabora el engaño en torno a una historia, ejerciendo un rol.
  Todo para ganarse la confianza de la víctima y tomar control de la situación.

  PROTECCIÓN: Si recibes una llamada que no esperas, ignora lo que digan y trata de colgar lo antes posible. Los soportes técnicos oficiales no se ponen en contacto contigo, salvo que tú lo hayas
  solicitado.

- Ejecución: El atacante pone en marcha su plan intentando manipular a la víctima para que le facilite la información que necesita o realice los pasos que se le indican.

  PROTECCIÓN: Antes de realizar ninguna acción, comprueba que la persona o servicio que está detrás de la llamada o mensaje es realmente quien dice ser.
  Analiza todos los detalles y consulta a terceras fuentes de confianza en caso de duda.

- Salida: Conseguido el objetivo, el ciberdelincuente corta la interacción con la víctima e intenta borrar todas las “huellas” que haya podido dejar para no ser descubierto.

  PROTECCIÓN: Si crees haber sido víctima de un fraude, analiza tu dispositivo con un antivirus. Si instalaste algo, cambia tus contraseñas, revisa los movimientos de tu cuenta bancaria, y si facilitaste información personal, busca información sobre ti en Internet periódicamente para descartar que se esté haciendo un uso indebido de ella.

Ejemplos de ataque de Ingeniería Social

En 2007, un tesorero de Michigan cayó en una estafa en Nigeria que involucraba a un príncipe ficticio que quería escapar de Nigeria, pero necesitaba ayuda para sacar sus bienes del país. En cuestión de meses, el tesorero realizó múltiples pagos por un total de 185000 (de los cuáles 72000 dólares provenían de su propio capital) a los piratas informáticos detrás de la estafa. Mas tarde reveló que el resto del fondo provenía de 1.2 millones de dólares que había marlversado durante sus 13 años de servicio público.

En 2013, los piratas informáticos robaron la información de la tarjeta de crédito de mas de 40 millones de clientes objetivo. Según datos oficiales, los piratas investigaron el servicio de aire acondicionado exterior de la cadena de supermercados y atacaron a sus empleados con correos electrónicos de phishing. Esto permitió a los piratas informáticos obtener acceso a la red de Target y robar la información de pago de los clientes. Aunque el perpetrador nunca fue arrestado, Target pagó 18.5 millones de dólares en 2017 para resolver reclamos estatales.

En 2017, más de **1 millón de usuarios de Google Docs recibieron el mismo correo electrónico de phishing con el que uno de sus contactos intentaba compartir un documento**. Al hacer click en el enlace, los dirigió a una página de registro falsa de Google Docs, donde varios usuarios ingresaron su información de registro de Google. Esto dio a los piratas informáticos acceso a más de 1 millón de cuentas de Google, incluidos correos electrónicos, contactos, documentos en la nube y copias de seguridad de teléfonos inteligentes.

¿Cómo protegerse de la Ing. Social? Ser mas desconfiado en el entorno online.

- Instalar software antivirus de confianza. Ahorra tiempo y la molestia de verificar tus fuentes, mediante el uso de un software antivirus confiable, que pueda detectar mensajes o sitios web sospechosos.
- Cambiar la configuración de spam en el correo electrónico: Puedes ajustar la configuración de su email, para reforzar el filtro de spam si estos mensajes aparecen en tu bandeja de entrada. Según el cliente de correo electrónico que estés utilizando, el proceso puede ser ligeramente diferente.
- Investigar la fuente. Si recibes un email, un mensaje de texto o una llamada telefónica de una fuente desconocida, busca esa dirección o número de teléfono en un motor de búsqueda para ver que información aparece al respecto. Si el ataque fue un ataque de ingeniería social, es posible que el número o la dirección de correo electrónico, hayan sido identificados como tales antes. Incluso si los remitentes parecen ser legítimos y está tratando de estar seguro, verifíquelos de alguna manera.
- Si algo parece demasiado bueno para ser cierto, seguramente sea falso. En este tipo de ataque de ingeniería social, la intención y el sentido común pueden ser muy útiles. No confíes en las ofertas que prometen grandes recompensas por dinero o información. Y si la solicitud parece provenir de alguien que conoces, pregúntate. ¿Realmente me está pidiendo esta información de esta manera? ¿Seguro que quieres compartir este enlace conmigo?

2. Conocimiento de los principales lenguajes de programación orientados a la ciberseguridad

   La ciberseguridad es un campo en constante evolución por tanto, hay que familiarizarse en distintos lenguajes de programación, para llevar a cabo tareas específicas en ciberseguridad, como:

   - Pruebas de penetración
   - Análisis de malware
   - Desarrollo de herramientas de seguridad

   Lenguajes:

1. **PYTHON:** Uno de los lenguajes de programación mas populares en el campo de la ciberseguridad debido a su versatilidad y facilidad de uso. **Se utiliza para tareas como el análisis de malware, automatización de tareas de seguridad, el desarrollo de scripts para pruebas de penetración y la creación de herramientas de seguridad.**
2. **C/C++**: **Estos lenguajes son ampliamente utilizados para el desarrollo de aplicaciones de bajo nivel y herramientas de seguridad de alto rendimiento.** Son comunes en el desarrollo de controladores de dispositivos, análisis de memoria y exportación de vulnerabilidades.
3. **JAVASCRIPT:** Se utiliza en el ámbito de la ciberseguridad, principalmente, para analizar y evaluar amenzas en aplicaciones web, así como para desarrollar herramientas de seguridad en el contexto de la seguridad en aplicaciones web.
4. **SQL**: Se utiliza en la manipulación de bases de datos y es esencial para realizar pruebas de inyección SQL, que son comunes en la evaluación de seguridad de aplicaciones web.
5. **BASH**: **El scripting de shell en Bash es útil para la automatización de tareas en sistemas UNIX/Linux y se utiliza para la administración y recopilación de información en entornos de seguridad.**
6. **RUBY**: Conocido por su framework de pruebas de penetración llamado "Metasploit". **Se utiliza para realizar pruebas de penetración y explotación de vulnerabilidades.**
7. **PERL**: Aunque no tan popular como Python, Perl se ha utilizado históricamente en la ciberseguridad **para desarrollar scripts y herramientas, especialmente en el análisis de registros y la manipulación de datos**.
8. **GO (GOLANG)**: Apreciado en la ciberseguridad por su rendimiento y capacidad para desarrollar herramientas de seguridad eficientes. **Se utiliza en el desarrollo de software y herramientas de seguridad.**

3. Conocer los lenguajes que utilizan los hackers.

   Los hackers éticos (sombrero blanco) como los maliciones (sombrero negro) utilizan los lenguajes:

   - Python
   - C/C++
   - Javascript

   Para las técnicas y herramientas:

   - Phishing
   - Pruebas de penetración (Pen Testing)
   - Ingenieria social
   - Ataques de fuerza bruta y diccionario
   - Explotación de vulnerabilidades
   - Ataque DDoS
   - Ransomware
   - Sniffing de Red
   - Inyección de Código

Unidad 4. Riesgos de Seguridad

1. Conocimiento sobre las vulnerabilidades y riesgos de seguridad informática.

Las vulnerabilidades mas conocidas son: **Web Hacking**

- **Clickjacking**: El ataque consiste en **engañar al usuario para que haga click en un enlace, botón o imagen maliciosa que está oculta o superpuesta de forma transparente** en un área particular del sitio web (como un menú). Al hacer click lo redirigirá a un sitio fraudulento.
- **Cross-site Request Forgery (CSRF)**: **El ataque consiste en engañar a un usuario para realice determinadas acciones en una aplicación web vulnerable** sin que la víctima sea consciente de ello.
- **Cross Site Scripting (XSS):** La vulnerabilidad podría **permitir que un atacante ejecute código en el navegador de un cliente (víctima)**, recupere datos de sesión, cookies, redirija una conexión a un sitio web que contenga contenido malicioso y lance un ataque de phishing, a través de un servidor ataque de negación en su navegador.
- **Inyección SQL (SQL Injection):** Los ataques de inyección SQL involucran la **manipulación de parámetros de entrada que los clientes ingresan en sus aplicaciones web.**

  Modifique la solicitud SQL de la aplicación backend a través de una cadena de texto especialmente manipulada para recuperar consultas arbitrarias para descargar y recuperar información importante de la base de datos, o cargar archivos (shell inversa), puede omitir el sistema de autenticación sin usar credenciales legitimas.
- **Ejecución de código remoto (RCE):** Un atacante podría aprovechar esta vulnerabilidad para **ejecutar código arbitrario desde una aplicación web.** Este método permite el acceso inmediato a su computadora, alojar archivos, eliminarlos o modificarlos, instalar y ejecutar malware y, potencialmente, explotar otras vulnerabilidades en un sistema operativo o servicios instalados. Para promover el acceso a privilegios y recursos de otras empresas.
- **Inclusión de ficheros (LFI):** Consiste en cargar un archivo mientras la aplicación se está ejecutando como resultado de un error de programación de la aplicación, al no controlar la fuente del archivo contenido en el flujo de ejecución. **Este tipo de técnica se puede realizar de las siguientes formas:**
  - Archivo local incluido (LFI): esta técnica le permite descargar cualquier archivo del servidor.
  - Archivo remoto incluido (RFI): esto le permite cargar y ejecutar cualquier archivo en su servidor.
- Redirección de URL a sitio no confiable: Debido a que existen servicios web que implementan redicrecciones que se pueden usar de manera ilegal, un atacante puede aprovechar esta redirección desde un dominio legítimo para controlar a estos usuarios en un sitio web o web maliciosa. Es posible que sea redirigido al sitio.

2. Detección, análisis y anticipación a los riesgos de seguridad

Dispositivos **móviles**: En la era digital, **estos dispositivos no sólo almacenan una cantidad impresionante de información personal y confidencial, si no que también son una puerta de entrada a nuestro mundo digital,** conectándonos a aplicaciones, servicios en línea y redes sociales.

Sin embargo, esta omnipresencia de los teléfonos móviles también los ha convertido en un objeto de alto valor para los ciberdelincuentes. Es por eso, que la detección, el análisis y la anticipación de los riesgos de seguridad en dispositivos móviles se ha vuelto esencial en la actualidad.

Ataques a dispositivos móviles:

Todos los teléfonos pueden ser atacados. A medida que los nuevos conocimientos permiten un avance en las tecnologías móviles, los ciberdelincuentes saben doblegarlas e incluso aprovecharse de ellas, sin importar cuán sofisticados sean.

¿Cómo lo consiguen? Software creado por hackers.

¿Sabías que existe software para Android y otros dispositivos móviles creados por ciberdelincuentes? Este software se puede encontrar en sitios web gratuitos en internet. **Los piratas informáticos diseñan este tipo de software para sustraer datos de teléfonos móviles.**

Los piratas informáticos profesionales pueden utilizar fácilmente una **aplicación espia** que simplemente se instala en el teléfono que desean atacar. Solo en algunos casos, los piratas informáticos necesitan **acceso físico al dispositivo** para instalar estas aplicaciones.

El registro de pulsaciones de teclado (**keylogging**) es una técnica que necesita de la descarga de un software espía para robar datos en un teléfono antes de que pueda cifrarse. Este tipo de software también se puede utilizar accediendo físicamente al teléfono.

Los troyanos son un tipo de malware que se puede disfrazar en los smartphones para extraer datos importantes, como tarjetas de crédito y otra información personal. Para instalar troyanos, los ciberdelincuentes utilizan técnicas como el phishing, para atraer a sus víctimas.

Phishing

El phishing es una técnica que consiste en que los ciberdelincuentes se hacen pasar por una empresa o persona de confianza para obtener información confidencial. En tales casos, generalmente envían emails y mensajes de texto que contienen códigos, imágenes y texto de aspecto corporativo y oficial. Cuando un usuario hace click en dicho contenido malicioso, la URL puede infiltrarse en el teléfono a través de enlaces infectados con virus o software que puede sustraer información personal.

Ataques mediante números de teléfono

Para comprender como funciona este tipo de ataque, es necesario conocer y comprender las técnicas de piratería telefónica. El protocolo **SS7** es un sistema utilizado para interconectar redes de telefonía móvil entre sí, por que si queremos infiltrarnos en los móviles es necesario el acceso a este protocolo.

Los delincuentes que acceden al protocolo SS7 tienen la **posibilidad de grabar y reenviar las llamadas, leer mensajes y localizar dispositivos específicos**. Sin embargo, este protocolo tiene un grado alto de dificultad por lo que es complicado que una persona sin conocimientos utilice este método.

Ataques mediante tarjetas SIM

En agosto de 2019, al CEO de twitter le suplantaron la identidad para cambiar su tarjeta SIM. La técnica fue la siguiente, el ciberdelincuente llamó al proveedor de telefonía de la víctima y se hizo pasar por este, solicitando una nueva tarjeta SIM.

Convencido el proveedor, este desactiva la antigua tarjeta SIM y el delincuente consigue el número de teléfono de la víctima, accediendo a la información personal. La protección de nuestros datos personales es esencial para evitar que los piratas informáticos se hagan pasar por nosotros.

La compañía **AdaptativeMobile Security** descubrió una nueva forma de infiltrarse en los teléfonos móviles a través de tarjetas SIM, el llamado **Simjacker**. Este método es más complicado que el phishing por que el atacante envía una señal al teléfono de la víctima, cuando éste abre dicha señal, el hacker puede espiar su dispositivo e incluso localizar su ubicación.

Ataques mediante Bluetooth

Los hackers profesionales pueden usar **programas especiales para buscar dispositivos móviles vulnerables con conectividad Bluetooth disponible**. Estos tipos de ataques ocurren cuando un hacker está cerca del teléfono de la víctima, generalmente en una área densamente poblada. Cuando un hacker se conecta a bluetooth, tiene acceso a toda la información disponible y conexiones a Internet, pero necesita descargar los datos cuando su smartphone está cerca.

¿Como evitarlos?

Consejos para no convertirnos en sus víctimas.

1. **No se aleje de su móvil**: La forma más fácil para que un ciberdelincuente robe información de nuestro smartphone es acceder fisicamente a este. Por lo tanto, **es importante mantenerlo cerca en todo momento**. Si nos preocupa que nuestro teléfono haya sido extraviado y manipulado en medio de un grupo de extraños, verifiquemos su configuración y busquemos aplicaciones desconocidas.
2. **Cifre su dispositivo**: Cifrar nuestro teléfono móvil puede prevenir ataques y proteger las llamadas, mensajes y demás datos confidenciales. Para verificar si nuestro dispositivo está encriptado: si somos usuarios de iPhone podemos ir a Touch ID y Passcode, dirigiendonos hacia la parte inferior para activar su privacidad. Si por otro lado, somos usuarios de Android podemos aprovechar el cifrado automático según el tipo de teléfono móvil.

3. **Bloquee su tarjeta SIM:** Podemos proteger nuestra contraseña de ataques agregando un código de acceso a su tarjeta SIM. Para iPhone, este código se puede configurar en Configuración > Datos móviles > PIN de la tarjeta SIM. Introducimos nuestro PIN existente para habilitar el bloqueo. Los usuarios de Android pueden ir a Configuración > Pantalla y bloqueos de seguridad > Otras configuraciones de seguridad > Configuración de bloqueo de tarjeta SIM. Aquí puede habilitar la opción para bloquear la tarjeta SIM.
4. **Desactive las conexiones wi-fi y Bluetooth**: Es muy fácil para los ciberdelincuentes conectarse a nuestro teléfono móvil a través de una conexión Wi-Fi o Bluetooth. Se recomienda que deshabilite estas conexiones si no las estamos utilizando. También es aconsejable no conectarnos a redes públicas.
5. **Use protección**: Podemos proteger nuestro dispositivo frente a spyware y malware de manera fácil y gratuita utilizando aplicaciones de seguridad móvil para iPhone y Android y así evitar que los ciberdelincuentes ataquen su móvil. Antivirus como McAfee, AV, Panda, Karspersky, Norton, Avast, ...

Seguridad en dispositivos móviles

Los dispositivos móviles, incluidos los que se usan simultáneamente de manera personal y profesional (BYOD), deben estar contemplados en las políticas de seguridad de la empresa, ya que existen riesgos inherentes a su uso como robo o pérdida, infección por malware, accesos no autorizados a recursos de la empresa o fugas de información.

Si no existen estas políticas o no contemplan los usos permitidos de los móviles, estaremos expuestos a sufrir incidentes de seguridad.

Para la elaboración de estas políticas podemos utilizar las **soluciones de gestión de dispositivos móviles (MDM) y las soluciones de aplicaciones móviles (MAM)** diseñadas para controlar el uso de dispositivos móviles.

Podemos utilizar las **soluciones MDM para aplicar las políticas de seguridad que consideremos necesarias**. Por ejemplo, podríamos utilizar este software para requerir el uso de un PIN para desbloquear un dispositivo móvil, permitir que las tecnologías de cifrado protejan los datos confidenciales almacenados, así como determinar si un dispositivo móvil ha sufrido modificaciones de software para evadir las restricciones del fabricante. (comúnmente conocido como rootear en el caso de los móviles Android o jailbreak en el caso de iPhone).

Una organización puede establecer diferentes políticas de gestión de dispositivos móviles para cada categoría, como por ejemplo los emitidos, por la organización, controlados por terceros y BYOD, y así tener en cuenta todos los niveles de acceso.

Además proporciona un entorno que aísla las aplicaciones y los datos de la empresa del resto del dispositivo pudiéndose requerir una autenticación robusta para acceder al entorno empresarial, que a su vez está cifrado para proteger los datos y aplicaciones confidenciales de la organización, y para minimizar los datos de esas aplicaciones a otras aplicaciones y servicios que se ejecutan en el dispositivo.

La opción mas completa para mantener la seguridad de estos dispositivos es el software conocido como UEM, (Unified Endpoint Management), que permite administrar de forma centralizada todos los dispositivos de la empresa de manera remota.

Esta herramienta **aúna las características de la gestión de dispositivos móviles o MDM y la gestión de movilidad empresarial EMM (Enterprise Mobility Management),** simplificando así el coste en tiempo y recursos en labores de administración.

Los UEM, además de permitir a la empresa gestionar los dispositivos móviles, proporcionan las herramientas necesarias para administrar otros elementos corporativos como impresoras, dispositivos IoT o equipos de sobremesa.

Las organizaciones pueden aprovechar estas capacidades de gestión de la seguridad, por ejemplo, **restringiendo la instalación y el uso de aplicaciones a terceros, o proporcionando una serie de aplicaciones autorizadas.** No obstante las capacidades de seguridad y las acciones apropiadas **varían ampliamente según el tipo de dispositivo, las aplicaciones que necesite tener instaladas y los permisos solicitados por estas.**

Por ello, las organizaciones deben proporcionar a los administradores de dispositivos y a los usuarios las pautas necesarias para protegerlos, ya que ambos administradores y usuarios, son responsables de la seguridad de los dispositivos móviles de teletrabajo.

Consejos de seguridad para móviles:

1. Limitar las capacidades de red, como por ejemplo el uso de Bluetooth y redes inalámbricas compartidas, priorizando en estos casos el uso de redes móviles (3G/4G/5G). Existe la posibilidad de que algunos protocolos inalámbricos expongan al dispositivo a un posible ataque por parte de los ciberdelincuentes.
2. Los dispositivos que se conectan a Internet deben disponer de un software antimalware e incluso de cortafuegos habilitados para evitar ataques y accesos no autorizados.
3. Aplicar las actualizaciones y parches del fabricante cuando sea necesario para proteger al dispositivo de los ataques que explotan vulnerabilidades conocidas y no parcheadas.
4. Cifrar los datos almacenados en el dispositivo.
5. Requerir autenticación antes de acceder a los recursos de la organización.
6. Restringir las aplicaciones que pueden o no instalarse mediante listas blancas o negras.
7. Dada la similitud entre las funciones de los dispositivos móviles, especialmente a medida que aumentan sus capacidades y las de los equipos de sobremesa o portátiles, las organizaciones deberían considerar aumentar las medidas de seguridad hasta equiparlas con las de los equipos que se utilizan en las instalaciones de la empresa.

3. Conocimiento sobre los comportamientos que ponen en riesgo nuestra seguridad en entornos digitales.

Formas de ataque

No se puede bajar la guardia, un ciberdelincuente siempre esta pendiente de sacar nuevas formas de atacar a los usuarios. Las formas de ataque pueden ser:

1. **Ataques a contraseñas:** Nuestra privacidad se verá comprometida si acceden a las contraseñas. Las contraseñas dan acceso a información personal y a servicios. Los ciberdelincuentes pueden acceder a tu información personal o servicios. Pueden acceder de dos maneras:
    1. Fuerza Bruta: Mediante la repetición, es decir, a base de ensayo y error, se intenta descifrar la contraseña.
    2. Por diccionario: Adivinan nuestra contraseña mediante un software, que hace diferentes comprobaciones de forma automática hasta que da con ella.

    ¿Cómo me protejo?

    - Utiliza contraseñas robustas y el factor de autentificación múltiple.
    - No compartas tus contraseñas con nadie.
    - No utilices las mismas contraseñas en diferentes servicios.
    - Cuidado con las preguntas de seguridad.
    - Utiliza gestores de contraseñas.
2. **Ataques por ingeniería social**: Basándose en la manipulación o el engaño, los ataques por ingeniería social utilizarán las técnicas necesarias para que los usuarios den a conocer su información personal o, incluso, les permita tomar el control de sus dispositivos.
    - **Phishing, Vishing y Smishing**: Son muy similares en su ejecución, El ciberdelincuente enviará un mensaje suplantando una identidad legítima, como una de nuestras redes sociales, un banco, una entidad pública. **El mensaje es de carácter de urgencia y/o con un atractivo especial**.

      Cuando se trata de un ataque a una persona en concreto se denomina **Spearfishing**, previamente se consigue toda la información posible sobre ella, para así tener una mayor probabilidad de éxito a la hora de hacer luego con el objetivo (dinero, información, etc).

      ¿Cómo me protejo? **Se precavido y lee el mensaje detenidamente, especialmente, si se trata de entidades con peticiones urgentes, promociones o chollos demasiado atractivos.**Y además:

      Detectar errores gramaticales en el mensaje

      Revisar que el enlace coincide con la dirección a la que apunta

      Comprobar el remitente del mensaje.

      No descargar ningún archivo adjunto y analizarlo previamente con un antivirus.

      Ejemplo de una noticia real: Estafan más de 9 millones de euros a la farmacéutica Zendal en O Porriño. El grupo farmacéutico Zendal, con sede en O Porriño, ha sido **víctima de una millonaria estafa** con la técnica del *phising*. Un responsable de esta compañía realizó transferencias a una cuenta bancaria por **más de nueve millones de euros** creyendo que lo hacía por orden de su jefe, cuando en realidad se trataba de un ciberdelincuente que había suplantado su identidad.

    - **Baiting o Gancho**: Se utilizan técnicas de abandonar unidades infectadas (USB) en la entrada de empresas o lugares de gran afluencia. Anuncios/webs en las que son promocionados premios o concursos para lo que nos solicitan datos o incluso descargarse algún archivo.

¿Cómo me protejo? **Evitar dispositivos de almacenamiento desconocidos.**

Antivirus activado y actualizado

Sistema actualizado

No fiarse de ningún mensaje, promesa o promoción por muy atractiva que sea de una web poco fiable.

- **Shoulder Surfing**: Mirando "por encima del hombro", desde una posición cercana nos controlan cuando estamos utilizando nuestros dispositivos.

  ¿Cómo me protejo? **No acceder a nuestras cuentas o evitar aportar información en lugares públicos.**

  Usar gestores de contraseñas.

  El sistema de verificación de dos pasos.

  Contemplar el uso de filtros "anti espias"

- **Dumpersert Diving**: o buscar en la basura. Aprovechan cualquier información sobre nosotros o nuestro trabajo y que pueda ser susceptible de utilizar en otro tipo de ataques.

  ¿Cómo me protejo? **Eliminar de forma segura nuestra información**

- **Spam**: Técnica masivo de envío de mensajes . Estos mensajes no deseados suelen tener una finalidad comercial, pero los hay que contienen algún tipo de malware.

  ¿Cómo me protejo? **Ignorar y eliminar este tipo de mensajes**

  Usar filtros antispam

  Adoptar las medidas de protección ofrecidas por las redes sociales.

  No utilizar nuestra cuenta de correo principal en registros de promociones u ofertas.

- **Fraudes online** : Los fraudes son de muy diversas variedades por lo que necesitaremos unas medidas de protección adaptadas casi a cada tipo en cuestión.

  ¿Cómo me protejo? **Desconfiar en principio de cualquier propuesta online que se nos haga**

3. **Ataques a conexiones**

   A trravés de diferentes software y herramientas los ciberdelincuentes atacan las redes inalámbricas. Se interponen entre nosostros y un servicio web, para así robar y monitorizar nuestros datos. Tipos:

   - **Redes trampa**: Práctica de duplicado de redes wifi con software y hardware. La configuran con los mismo parámetros.

     ¿Cómo me protejo? **Desconfía si ves dos redes con nombres similares.**

     Vigila que utilicen https

     Ojo si son abiertas o te permiten acceder con cualquier contraseña.

- **Spoofing**: Tecnicas de suplantación de nuestra identidad "hacking". Con esta suplantación tienen un acceso a nuestra información

  ¿Cómo me protejo? **Estar alerta y seguir las recomendaciones sobre la navegación segura**

  Vigilar las URL que sirven de enlace

  Desconfiar de webs sin https:// ni certificados digitales.

- **Ataques cookies**: Las cookies son enviados por un servidor web a nuestro dispositivo. Si se realiza sin protocolo https//: será visible para los ciberdelincuentes.

  La función de una cookie es aportar rapidez a futuras navegaciones recordando información empleada.

  Si se roba o se modifica la información que contiene una cookie estamos hablando de un ataque a cookies.

  ¿Cómo me protejo?

  Tener siempre actualizado el navegador

  Eliminar cookies periódicamente

  Atender siempre y revisar con cuidado las notificaciones o mensajes.

  Utiliza el método incognito disponible en tu navegador.

- **Inyección SQL**: Como usuarios poco se puede hacer para prevenir, ya que depende de la seguridad implantada por el servicio web, en el caso de los desarrolladores web , deben seguir las recomendaciones basadas en el código seguro y que priorice la privacidad de las comunicaci´on y la protección de nuestros datos.

  Las bases de datos utilizan el SQL como lenguaje de programación. Inserta líneas maliciosas de este mismo código SQL en la aplicación web y así obtiene el acceso a los datos.

  ¿Cómo me protejo? Es una cuestión de la seguridad implantada por el servicio web.

- **Escaneo de puertos**: También llamado **portscan** . Analizan los puertos de los dispositivos que se encuentran conectados a una red. De esta manera se sabe cual de ellos está cerrado, abierto o si cuentan con algún protocolo de seguridad.

  ¿Cómo me protejo? **Configura tu router**

  Utiliza un filtrado MAC para controlar las conexiones entrantes y los dispositivos conectados.

  Tener el firewall activado en todo momento.

  Controlar en todo momento los puertos abiertos

  Mantenerlo actualizado siempre.

- **Man in the middle**: El ciberdelincuente monitoriza cualquier actividad online en una red infectada. El atacante se sitúa entre el servidor con el que nos comunicamos y nosotros

  ¿Cómo me protejo? **No conectarse nunca a redes públicas**.

Si necesitas conexión a estas wifi que sea a través de VPN

Dispositivos actualizados.

Contraseñas robustas, verificación en 2 pasos y utilizar aplicaciones de cifrado.

Web con protocolo https//:

- **Sniffing**: El ciberdelincuente escucha todo lo que ocurre en una red.

  ¿Cómo me protejo? Antimalware que pueden detectar y eliminar los sniffers instalados en un equipo. Sin embargo dado que no son considerados como malware, no siempre son detectados y deben ser eliminados de forma manual.

  No descargar archivos adjuntos sospechochos.

  No navegar por webs fraudulentas.

  Evitar conectar dispositivos USB desconocidos.

4. Correos adjuntos:

   Si no lo conoces no lo abras, pueden contener archivos .pps, .exe o .zip. Podemos analizar el correo con antivirus o antimalware.

   Deberíamos utilizar diferentes cuentas de correo:

   - una para el uso personal,
   - una el trabajo
   - otra para suscripciones y correos comerciales

   Debemos evitar enviar información por email

5. Memorias y discos externos:

   Las memorias externas (USB, CDs, DVDs) son las principales herramientas para infectar equipos, ya que pueden contener archivos infectados. para ello debemos utilizar un antivirus y analizar dicha memoria.

4. Capacidad de detección incipiente de los riesgos y minimización de los efectos de los daños producidos en la seguridad digital.

Conoce a tu enemigo y conócete a ti mismo

La principal amenaza que preocupa a casi un tercio de los expertos en IT, es el phishing, seguido de cerca de los troyanos, de acuerdo con un informe elaborado por BitDefender.

Estos dos datos ponen de manifiesto la transcendencia actual de la ciberseguridad en las organizaciones y los motivos por los que ya es imprescindible. Las empresas necesitan armarse y protegerse, de un modo similar a como sucede durante el transcurso de una guerra, contra posibles violaciones que atenten contra su seguridad.

Conviene recordar que, una vez más los ciberataques continúan ocupando un lugar destacado en el ranking de las amenazas más temidas a nivel mundial.

En el mundo real, nadie puede conocer cada una de las amenazas potenciales a futuro o cuando éstas atacarán. Es por esto que Nueva York, Londres y otras áreas metropolitanas han instalado un sistema de cámaras. Para que cuando se produzca una situación de este tipo, puedan reunir información y responder con una investigación rápidamente.

Conocer a tu enemigo no se trata de predecir el futuro, se trata de entender tus debilidades, identificar los puntos ciegos y desarrollar estrategias de mitigación, para reaccionar a posibles amenazas de tu enemigo.

Algunos ataques están dirigidos a la infraestructura de red, otros, a la nube, o inclusive a sus dispositivos móviles. Hay casos donde los routers han sido usados contra sus propias organizaciones.

Posiblemente, el principio mas crítico que uno aprende en ciberseguridad es saber donde están ubicados nuestros activos estratégicos.

El primer paso para construir una estrategia de ciberseguridad sólida es tener visibilidad sobre cada aspecto de los datos críticos, incluyendo información vital que se mueve continuamente a lo largo y ancho de la red, dispositivos e infraestructuras Cloud.

No puedes saber donde o cuando vendrá el siguiente ataque, pero si te puedes preparar para detectarlo lo más rápido posible. Se trata de conocer a tu enemigo y tener una imagen completa de lo que pasa antes, durante y después de un ataque. Lo más rápido que puedas ver y responder, menor será el daño infligido.

Unidad 5. Implementación de buenas prácticas en entorno digital.

1. Capacidad de búsqueda y localización de información sobre buenas prácticas en las entidades oficiales de gestión de la ciberseguridad (CCN-CERT o INCIBE)

¿Donde buscar y localizar información sobre ciberseguridad?

1. **Centro criptológico nacional (ccn-cert):** Capacidad de respuesta a incidentes de seguridad de la información del Centro Criptológico Nacional (CNN). https://www.ccn-cert.cni.es/es/

   Su misión, por tanto, es contribuir a la mejora de la ciberseguridad española, siendo el centro de alerta y respuesta nacional que coopere y ayude a responder de forma rápida y eficiente a los ciberataques y a afrontar de forma activa las ciberamenazas, incluyendo la coordinación a nivel público estatal de lass distintas Capacidades de Respuesta a Incidentes o Centros de Operaciones de Ciberseguridad existentes.

2. **Instituto Nacional de Ciberseguridad (INCIBE)**: Trabaja para afianzar la confianza digital, elevar la ciberseguridad y la resilencia y contribuir al mercado de manera digital de manera que se impulse el uso seguro del ciberespacio en España. https://www.incibe.es/

   INCIBE, anteriormente Instituto Nacional de Tecnologías de la Comunicación, es una sociedad dependiente del Ministerio de Asuntos Económicos y Transformación Digital a través de la Secretaria de Estado de Digitalización e Inteligencia Artificial y consolidada como entidad de referencia para el desarrollo de ciberseguridad y de la confianza digital de los ciudadanos,

red académica y de investigación, profesionales, empresas y especialmente para sectores estratégicos

Recursos que ofrecen:

- Amplia gama de información
- Guía y recursos

2. Capacidad de implementar buenas prácticas en el entorno digital a través del conocimiento de los principales mecanismos de protección (gestión segura de contraseñas, gestión y control de los sistemas de antivirus, control de accesos y aplicaciones críticas)

La creciente dependencia de tecnología y la expansión de nuestras vidas online. Ha creado un escenario en el que estamos constantemente bajo amenazas, por ello tenemos principales mecanismos de protección, comprender y dominar:

- Mantener sistemas y dispositivos actualizados.

  Es muy importante tener actualizado nuestro sistema y nuestro software para evitar vulnerabilidades. Si no lo hacemos nos exponemos a robo de información, pérdida de privacidad, suplantación de identidad, etc.

  Debemos tener la opción de actualizaciones automáticas activada siempre que sea posible. Tenemos que ser especialmente cuidadosos con los sistemas operativos, navegadores y programas antivirus. También con las aplicaciones que instalamos sean fiables. Debemos evitar software y sistemas operativos antiguos que no dispongan de actualizaciones.
- Gestión de nuevas contraseñas
- Salvaguardar nuestra red
- El control de red y el uso efectivo de firewalls

1. Cómo proteger nuestros equipos y datos

   ¿Qué es una actualización?

   Las aplicaciones y los sistemas operativos instalados en nuestros dispositivos, periódicamente tienen modificaciones o añadidos que mejoran funcionalidades, tales como la seguridad. Estas mejoras son las actualizaciones.

   ¿Cómo proceder?

   - Estar atento al estado de actualización de todos nuestros dispositivos y aplicaciones.
   - Siempre que esté disponible, es conveniente seleccionar, la opción de actualización automática.
   - No esperar a instalar las actualizaciones existentes. Hacerlo cuanto antes, sobre todo en los sistemas operativos, navegadores y antivirus.

- Vigilar mucho los privilegios que concedemos al instalar aplicaciones y huir de fuentes no confiable.
- No hacer uso de sistemas operativos o aplicaciones anticuados que no tengas actualizaciones de seguridad.

¿Cómo actualizar?

- Sistemas operativos
  - Windows 10: Configuración > Actualización y seguridad

    Disponemos de actualizaciones:

    - acumulativas
    - de características
    - opcionales

    Opciones de actualizaciones:

    - Pausar las actualizaciones
    - Cambiar las horas activas
    - Ver historial
    - Opciones avanzadas
  - Mac OS: Manzana > acerca de este Mac > Manzana > preferencias del sistema
- Navegadores: Es recomendable disponer de las últimas versiones
  - Chrome: chrome://settings/help
  - Edge: edge://settings/help
  - Firefox: about:preferences
  - Opera: opera://update

Copias de Seguridad

Es muy importante que hagamos copias de seguridad o backups. Estas copias nos van a permitir recuperar archivos en caso de pérdida, robo, ataque o infección por virus.

Es recomendable, guardar estas copias en lugares distintos a los de los datos originales.

Hay que seleccionar de que queremos hacer la copia de seguridad, por que hay un límite, es importante incluir archivos personales, archivos que supondría un gran problema perderlos.

Hay otro tipo de información que si podríamos recuperar: música, películas.

La periocidad con que realicemos la copia dependerá de la cantidad de movimiento de información que realicemos en nuestro equipo.

¿Cómo proceder?

Guardamos la información en memorias externas, que se podrían estropear y perder la información.

Es importante ser previsores. Se deben hacer copias de seguridad, periódicamente, de la información que se considere más relevante. Dicha copia se realizará en diferentes dispositivos o soportes, por si uno de ellos fallase, poder recuperarla.

Utilizar un sistema fiable, que nos de seguridad al realizar las copias

Conocer las características de la nube que vayamos a utilizar y valorar, antes de nada, si nos conviene utilizarla.

Tener cuidado con las aplicaciones que instalamos y vigilando los privilegios que le concedemos.

La utilización de sistemas de cifrado robustos siempre es recomendable, ya que si lo que queremos proteger es información sensible debemos protegerla correctamente.

¿Cómo hacer un backup?

- Sistemas operativos
  - Windows 10: Configuración > copia de seguridad (se puede hacer o recuperar una copia de seguridad)
  - MAC OS: Manzana > preferencias del sistema > time machine
- Agentes externos

  Podemos programar desde imágenes de disco hasta archivos personales. Vamos ha hacer una prueba con CobianSoft. https://files.combiansoft.com/programs/cdSetup.exe

2. Cómo proteger nuestra red
   -

Uso correcto del wifi

Cuando nos conectamos a una red wifi debemos tener mucho cuidado para no caer en una trampa. Consejos:

- Comprobar que la red es auténtica. El proveedor tendrá un cartel con los datos de acceso en la pared.
- Es preferible conectarnos a una red con seguridad WPA o WPA2.
- Las redes abiertas o con seguridad WEB son muy inseguras. Usaremos la VPN de nuestra empresa.
- Debemos deshabilitar cualquier proceso de sincronización de nuestro equipo antes de conectarnos.
- Mantener el sistema actualizado y con un antivirus correctamente instalado.
- Evitaremos páginas inseguras que no empiecen por https.
- Realizar transacciones financieras o iniciar sesión en ningún servicio.
- Trás la conexión, eliminaremos los datos de red memorizados.

¿Cómo se debe montar y configurar una red WIFI?

La **configuración del router**: Existen 3 configuraciones que debemos realizar en el momento que la red esté instalada. Para ello, lo primero que haremos desde un ordenador conectado por cable, será acceder al router a través de una dirección IP tipo: https://192.168.X.X que insertaremos como URL en nuestro navegador. Los datos de acceso los encontrarás normalmente en el manual de instrucciones o, incluso en la parte inferior del router.

Configuraciones básicas

- Cambiar las credenciales de acceso.

Es importante que al acceder por primera vez a tu router cambies los datos de acceso que vienen de fábrica por unos nuevos, para evitar el acceso a la configuración de cualquier persona ajena.

- Cambiar la contraseña de acceso a la red
- Configurar el tipo de cifrado de la red

  Utilizar el cifrado WPA2 con encriptación AES es el mas seguro para nuestra red de casa. Con ello, lo que conseguimos es que alguien que esté monitoreando datos no pueda acceder a los nuestros porque serán ilegibles.

Configuraciones avanzadas

- Configurar el firewall

  Esta opción se podrá elegir siempre y cuando el router lo permita. Podremos elegir que puertos y servicios queremos que estén disponibles para un acceso externo a la red.
- Acceso a router por https

  Con esta opción lo que haremos, será configurar nuestro acceso a router a través del protocolo HTTP seguro para evitar que un atacante capture nuestra contraseña de acceso a la configuración.
- Ocultar el SSID (Server Set IDentifier) de la red:

  Este es el nombre que identifica a nuestra wifi. Debemos cambiar el nombre de la misma y ocultarlo para que no aparezca en el listado de redes disponibles.
- Configurar SSID de invitados.

Consideraciones para redes wifi públicas

- Cerciórate de que la URL comienza por https://
- Conéctate a través de una VPN
- Evita conectarte a redes inalámbricas abiertas
- Es preferible el acceso a una red con WPA o WPA2
- Deshabilita cualquier proceso de sincronización
- No inicies sesión en servicios comprometidos.

Asegura tu red local

Muchas veces creemos que con tener un antivirus instalado es suficiente. Consejos

- Debemos cambiar la contraseña del administrador. A veces dejamos la que viene por defecto y puede ser muy simple. Conviene cambiarla por una mas compleja y que elijamos nosotros. Además jamás dejaremos la red abierta. De ser así, cualquiera podría conectarse a ella y robar datos personales o cometer algún delito informático.
- Tenemos que mantener el equipo actualizado en todo momento. Debemos tener un antivirus y un firewall.
- A ser posible, debemos activar la administración remota y hacer que la IDE no sea visible. Todo esto hará mas difícil el hackeo de nuestra red.
- Otras opciones para mantener los puertos de nuestra red interna protegidos es habilitar el filtrado MAC para controlar el acceso a la red, permitiendo o denegando el acceso de cada dispositivo. Por otro lado activaremos el bloqueo por cambio de equipo

VPN (Virtual Private Network) (Red virtual privada)

Es una extensión para acceder desde una red pública a una red local conocida, permitiendo que todo el tráfico generado por un usuario sea transmitido a través del VPN de manera cifrada y por lo tanto segura.

Para que todos los usuarios puedan trabajar en el **mismo entorno de red**.

Eliminar barreras de distancias.

Debido a su **gran versatilidad y sus múltiples usos**, se han hecho muy populares entre todo tipo de usuarios.

Versatilidad:

- Salto de bloqueos geográficos. Por lo que si te encuentras en otro pais o continente, te situarán en el mismo sitio original que dicha conexión.
- Permitirá tener un mayor anonimato en la red.
- Servirá de bloqueo de publicidad.

Es fundamental, que si se dispone de una VPN corporativa configurada, se use. Igualmente, muchos router domésticos permiten su configuración, por lo que se tendrá que leer el manual para poder configurar una seguridad mas avanzada.

La VPN tiene la capacidad de crear una red local sin necesidad de que sus integrantes estén físicamente conectados entre si, si no a través de internet, saltándonos los bloqueos geográficos.

Control de Red:

Podemos utilizar nuestro propio router para tener definidos que dispositivos acceden a nuestra red.

Existe software de escaneo de red.

Uso de firewall

Un firewall o cortafuegos permite controlar y restringir las comunicaciones entre las partes. Están diseñados para evitar los accesos no autorizados a las redes privadas, especialmente intranets. Este dispositivo monitoriza los datos entrantes y salientes. Para que funcione, hay que crear un conjunto de reglas para determinar que accesos están autorizados y cuáles deben ser bloqueados.

Funciona a modo de barrera entre internet y nuestra red. Existen dos tipos de firewall, software o hardaware

- Firewall por software: es más básico, pensado para instalaciones domésticas
- Firewall por hardware: normalmente se instala en los routers, de manera que los ordenadores con acceso a esta red estarán protegidos por este cortafuegos. Aún así es posible la combinación de ambos para una mayor protección.

- Un firewall sirve para preservar nuestra seguridad y privacidad, para proteger nuestra red doméstica o empresarial, para tener a salvo la información almacenada, para evitar intrusiones no deseadas de terceros y para evitar posibles ataques.
- Las reglas a implementar: administrar los accesos de usuarios de red, registrar los intentos de entrada y salida de la red, filtrar por protocolos utilizados, controlar el número de conexiones de un mismo punto y limitarlas. Aún así conviene recordar que el firewall no debe ser la única protección de nuestro ordenador o red, ya que existen por ejemplo vulnerabilidades locales, como introducir un USB o borrar contenido de un ordenador o ataques externos que no pasen por el.
- En resumen, el firewall sirve para controlar y bloquear el acceso no autorizado a redes privadas mediante un conjunto de reglas, supervisando los datos entrantes y salientes.

¿Qué es un firewall o cortafuegos?

La palabra "firewall" en un sentido concreto significa, algo así como "muro cortafuegos".

Pared que separa el motor de funcionamiento de un determinado dispositivo y un riesgo externo que puede pejudicarle. Filtra información recibida a través de la red.

Principal Función: Inhabilitar todo acceso no autorizado a los dispositivos que protege.

Dispositivos internos de la red de daltos (LAN) desde conexiones externas de internet (WAN)

Es una manera de controlar y restringir la comunicación.

Cuando el firewall está bien configurado, **los hackers no pueden entrar y hacerse con información importante y privada.**

También, es capaz de **manejar el uso de internet salvándolo de material inapropiado.**

Podemos utilizar el firewall de nuestro sistema operativo, existen firewall de otros fabricantes, la mayoría de routers también disponen de firewall.

3. Uso de contraseñas

Si utilizamos una mala contraseña o si utilizamos siempre la misma. Es fácil que un hacker pueda acceder a ella. No son pocos los hackers que se dedican a vender datos sustraidos de miles o incluso millones de personas.

Un primer consejo, es no utilizar la misma contraseña o no utilizar la misma contraseña para varias cosas. Esto es algo que tendemos a hacer para acordarnos fácilmente de ellas. Pero piensa que también de esta forma se lo ponemos fácil a un hacker, ya que una vez descubierta la conraseña, podrá acceder a todos nuestros sistemas.

Por otra parte, tiene que ser una contraseña larga de mas de diez o 12 caracteres y siempre mezclando letras, números y símbolos.

Tenemos que olvidarnos de contraseñas simples tipo 1234. Nuestro nombre,apellidos, año de nacimiento o palabras sencillas, así como tampoco debemos nunca utilizar como contraseña, el nombre de usuario o la que nos ofrece el sistema por defecto. Existen muchos trucos para crear una buena contraseña. Lo mejor es quedarnos con el que más nos convenza y nos resulte fácil de recordar. Podemos partir de una frase que tenga significado para nosotros y quedarnos con la primera letra de cada palabra. Otra opción puede ser combinar dos palabras entremezclando sus letras.

También podemos convertir las vocales en números o eliminarlas por completo. Estos son algunos consejos recomendados, pero puedes crear tu propio truco.

¿Qué son las contraseñas?

Abren la puerta a nuestros datos personales, éstos que queremos mantener a salvo bajo cualquier concepto.

Numero de teléfono móvil, mensajes de correo y chat, transacciones bancarias, información sobre pedidos online, etc.

Tiene que ser fácil de recordar, robusta, utilizando un regla nemotécnica.

Errores más comunes:

- Reciclar contraseñas:

  Un error muy frecuente es utilizar la misma clave para múltiples cuentas o aplicaciones.
- Memorizar contraseñas en función del teclado

  Muchos usuarios usan el teclado como guia para recordar contraseñas fácilmente. Ej: "123456" o "qwerty"
- Usar expresiones hechas.

  Utilizar palabras como "teamo", "iloveyou", "teodio", etc
- Utilizar aficiones

  Algunos usuarios fanáticos suelen usar el nombre de sus marcas, deportes, equipos o bandas de música favoritos.
- Apuntarlas en notas

  Aunque se haya creado una clave robusta, nunca se debe dejar por escrito y mucho menos dejarla a la vista de cualquiera.
- Hacer uso de patrones sencillos.

  Como que la primera letra esté en Mayúscula seguida de 4 o 5 en minúscula o usar uno o dos números y finalizar con un carácter especial como un punto o signo de exclamación Ej: "Perro26!"

Debemos utilizar claves diferentes en servicios diferentes.

- Cambiar vocales por números. Por ejemplo: Mi familia es genial-> M3 f1m3l31 2s g2n31l
- Utilizar reglas nemotécnicas. Por ejemplo: Elegir la primera letra de cada una de las palabras de una frase que sea fácil de recordar para nosotros. "Con 10 cañones por banda" -> C10cpb...
- Utilizar claves basadas en un patrón, como pequeñas variaciones para cada servicio. Por ejemplo: Tomando como base la contraseña anterior, añadir al final la última letra del servicio utilizado en mayúscula.

  Facebook -> C10cpb...K

  Twitter -> C10cpb...R

  Gmail -> C10cpb...L

Algunos servicios ofrecen la opción de utilizar preguntas de seguridad, para que en caso de olvido, podamos recuperar la contraseña. Sin embargo muchas de estas preguntas son simples y cualquier persona que nos conozca mínimamente o que disponga de acceso a nuestras redes sociales podría averiguar la respuesta.

Por ejemplo: ¿Cómo se llama tu mascota?. Por ello no podemos utilizar las preguntas de seguridad con respuestas obvias. Podemos facilitar una respuesta compleja o bien una respuesta falsa y sólo conocida por nosotros.

Gestor de contraseñas

Estos programas nos permiten almacenar las contraseñas protegiéndolas con una clave de acceso que solo nosotros conocemos.

- LastPass Manager
- PasswordBoss

4. Cómo protegernos en la red

A la hora de proteger veámos como hacerlo en nuestros dispositivos móviles personales y de trabajo.

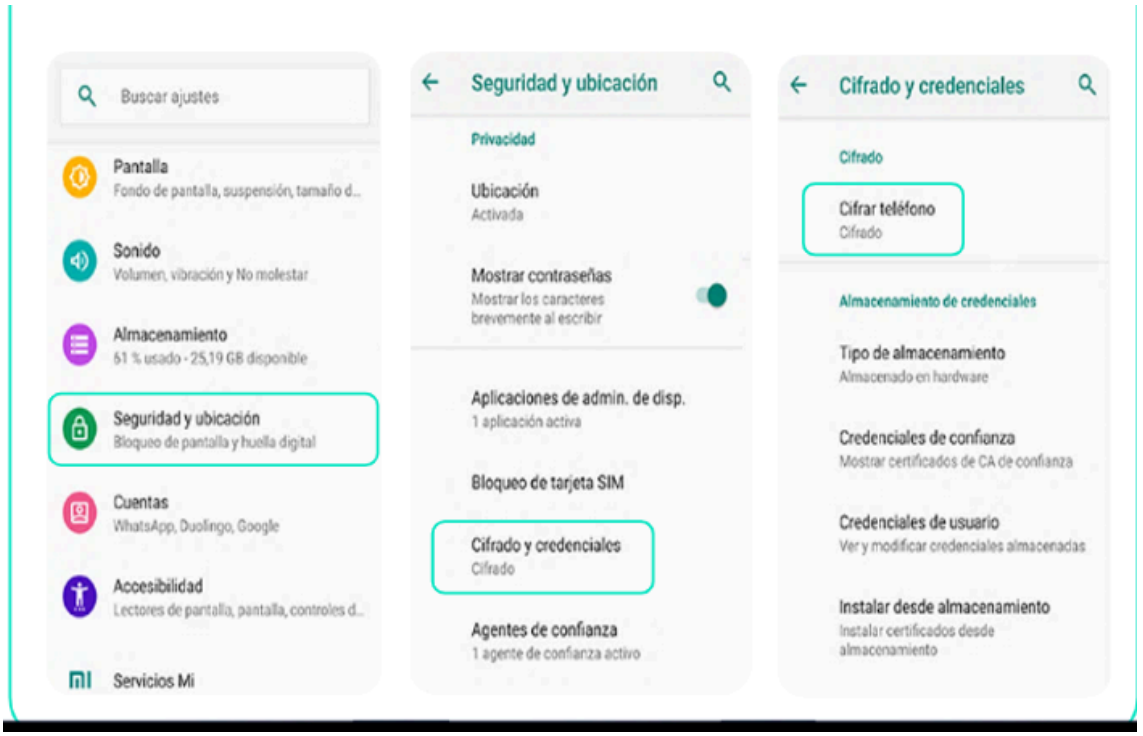
Toda la información contenida en nuestros dispositivos móviles es susceptible de ser sustraida en cualquier momento, ya sea por el robo del dispositivo o por un malware.

¿Que pasaría si perdiésemos el dispositivo y otros tuvieran acceso a la información almacenada. Y si se infectase nuestro dispositivo y los clientes o compañeros de trabajo recibieran correos con información personal. O si por nuestra culpa se infectase la red de trabajo. O si toda la información de un proyecto se borrase de un día para otro?

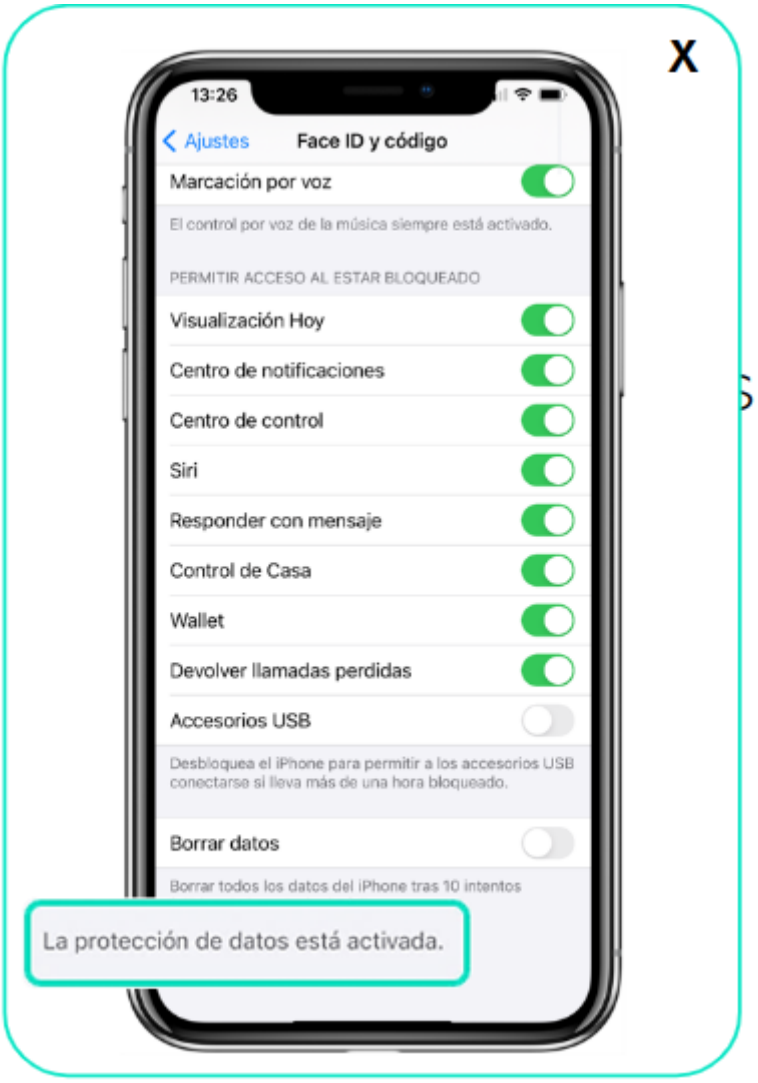
- Instalar y mantener actualizado un anitirus
- Separar las cuentas personales y las de trabajo
- Realizar conexiones seguras
- Utilizar un cortafuegos
- Realizar copias de seguridad

¿Cómo cifrar los dispositivos móviles?

Cifrado en Android



Cifrado en IOS



Seguridad en dispositivos móviles

Un dispositivo móvil es como un mini ordenador. Tiene grandes ventajas: movilidad, conectividad, fácil acceso, versatilidad, etc.. Pero hay que ser consciente de los riesgos que estas ventajas acarrean. Un smartphone puede sufrir mas fácilmente que un ordenador, una perdida o un robo.

¿Alguna vez has perdido el móvil? ¿Tienes fotos o información que no quieres que vea nadie?

Pautas para mantener tus datos seguros:

- Habilitar el Google device Locator o iCloud en dispositivos IOS para poder localizar, bloquear y eliminar los dispositivos de manera remota.
- En caso de móviles android cifraremos el terminal y la tarjeta SD. Los móviles no quedan libres de infecciones de virus. Será muy recomendable instalar y mantener actualizado un antivirus. Además debemos apagar el dispositivo por la noche cuando no está siendo utilizado. Muchos ataques se producen cuando no estamos al tanto de ello.
- Otro posible riesgo es el robo de información por Bluetooth. Lo mantendremos desactivado cuando no lo necesitemos.
- Debemos ser cautelosos con nuestros datos confidenciales. Evitaremos facilitarlos en conversaciones, emails o SMS. Por si alguien llegara a acceder a nuestro telefono.
- Es recomendable hacer copias de seguridad de la información que no queramos perder.
- Debemos implementar medidas como habilitar Google Device Locator, cifrar los accesos, instalar un antivirus o realizar copias de seguridad,

¿Has pensado alguna vez en las consecuencias de subir una foto a Facebook? ¿Te has visto comprometido por un comentario que ha escrito alguien?

Las redes sociales se han convertido en una nueva forma de comunicación a todos los niveles. Compartimos fotos y comentarios con muchísima gente, con tan solo hacer un click. Además hoy en día todos llevamos un móvil encima, lo que significa que tenemos conexión a internet en cualquier lugar y en cualquier momento. Lo mismo ocurre con las fotos. Disponemos siempre de una cámara. Si juntamos las fotos y las redes sociales, el resultado puede ser una bomba para nuestra intimidad. Debemos ser cuidadosos con los contenidos que se suben a las redes y con quien tiene acceso a ellos.

Una buena gestión de las redes sociales puede tener muchas ventajas, por ejemplo en cuanto a la comunicación, pero en caso contrario puede convertirse en un arma de doble filo.

Un buen consejo puede ser compartir información solo con aquellas personas que conocemos lo suficiente. Se tiende a aceptar solicitudes de amistad de desconocidos y eso hace que tengamos descontrolada la información. Tenemos que prestar especial atención a las imágenes tomadas dentro de un entorno empresarial.

En un caso así, podemos mostrar información confidencial inconscientemente. Debemos de tomar medidas de seguridad (antivirus, contraseñas, cerrar sesiones ,...) para preservar nuestra intimidad y la del entorno que nos rodea. Tenemos que ser cautelosos con lo que compartimos y con quien lo compartimos.

Hoy en día podemos comprar en internet prácticamente de todo, donde y cuando queramos.

Consejos para comprar de manera segura:

- Realizar compras en páginas que te inspiren confianza.

- Asegúrate de que en la web aparece identificado el responsable de la tienda online y su ubicación.
- Comprueba que la tienda online es segura y proporciona toda la información que necesitas sobre consumo y tratamiento de los datos personales.
- Si te es posible, utiliza una tarjeta de uso exclusivo para realizar pagos online.
- Desconfía de las ofertas demasiado atractivas, ya que podrías estar ante una web fraudulenta.
- No olvides comprobar que tus dispositivos están configurados correctamente y la conexión a internet es segura antes de proporcionar tus datos personales o tus datos de pago.
- Nunca envíes dinero en efectivo para completar una compra. Elige con cuidado el medio de pago.
- Recuerda que los comercios con sellos de confianza ofrecen mayores garantías.
- Puedes desistir de una compra o contrato sin tener que dar explicaciones en los 14 días posteriores.
- Si desistes o haces uso de la garantía, ello no debe tener coste alguno para ti, y esto incluye gastos de envío.

Sellos de confianza:

- Confianza online
- Aenor https://www.aenor.com/

Estos sellos se otorgan por:

- Declaración de buenas prácticas.
- Opiniones de clientes.
- Auditorías
- Certificación de una autoridad independiente.

Compras online

Día a día va aumentando el número de gente que compra sin moverse del sofá de su casa. La facturación de las tiendas online no deja de aumentar. Es una nueva forma de compra adaptada a una nueva manera de vivir.

Esta actividad en sí no debería ser peligrosa, pero debemos tomar una serie de precauciones para no caer en ninguna trampa. Cuando hagamos una compra online, debemos acudir a vendedores con gran reputación. Si no conocemos la web, nos aseguraremos de que hay alguien de referencia a quien podamos localizar personalmente o por teléfono.

Recomendamos indagar en buscadores, redes sociales y foros acerca de la tienda en la que vamos a comprar. Comprobaremos las opiniones que otros usuarios tienen sobre ella. La gente suele comentar las malas experiencias vividas a través de internet.

La página donde vamos a hacer la compra tiene que asegurar que la información que introducimos se mantendrá segura. Para ello nos fijaremos en que la URL comienza por https.// y muestra un candado. Además es conveniente que revisemos la política de envío y devolución. Para adelantarnos a posible problemas, es necesario también que tengamos nuestro dispositivo a punto. Debemos tener un antivirus instalado y el sistema actualizado. Las compras las haremos utilizando una conexión segura, evitando siempre las redes wifi públicas. Una vez verificada la página y con nuestro equipo a punto, antes de abonar nada, conoceremos todos los medios de pago y elegiremos el más adecuado.

Videoconferencias

El uso de la videoconferencia ha aumentado, medidas de seguridad y privacidad en las plataformas:

- OSI: oficina de seguridad del internauta https://www.incibe.es/ciudadania/
- aepd: agencia española de protección de datos. https://www.aepd.es/
- incibe: instituto nacional de ciberseguridad. https://www.incibe.es/

Si necesitas ayuda en ciberseguridad llamar al teléfono 017 (pertenece a incibe)

Colaboración ciudadana es importante para interceptar y localizar una ciberestafa.

¿Qué hacer ante una ciberestafa?

Centro de respuesta a Incidentes de Seguridad de referencia para los ciudadanos y entidades de derecho privado en España (INCIBE-CERT)

Reporte del fraude: https://www.incibe.es/ciudadania/ayuda/reporte-de-fraude

RECOPILACIÓN

- Tener nuestro equipo protegido ante cualquier ataque o intrusión.
- Antivirus y firewalls son fundamentales, así como tener continuamente nuestro equipo actualizado.
- Crear una contraseña segura
- Cerrar sesión cada vez que no estemos delante del ordenador y aseguraremos nuestro equipo desde el primer acceso.
- Ser cauteloso cuando naveguemos por internet, sobre todo en el caso en que nos conectemos a una red WIFI públicas.

- Aseguraremos nuestra red local y nos fijaremos en que las webs que utilizamos siguen el protocolo HTTPS.
- Evitaremos páginas peligrosas y en caso de tener mucha publicidad utilizaremos un bloqueador.
- Realizar copias de seguridad y utilizaremos los sistemas cloud. Incluso en el caso de disponer información sensible, encriptaremos o codificaremos los datos, evitaremos las memorias externas para transferir información y en él caso de deshacernos de un disco duro, utilizaremos una aplicación específica para el borrado de datos

3. Capacidad de identificación y clasificación de la información que se maneja en entorno digital y aplicación de las medidas necesarias para su protección que se plasmará en distintas políticas de seguridad informática.

Según la comisión europea: "Actualmente 250 millones de personas utilizan internet cada día en Europa. Cada vez compartimos más datos personales, ya sea a través de la banda electrónica, las compras por internet, las redes sociales o declaraciones tributarias electrónicas. Los consumidores valoran enormemente su privacidad en línea. El RGPD proporciona a las empresas la flexibilidad que necesitan para hacer un uso innovador de los datos personales, sin dejar de proteger los derechos fundamentales de los ciudadanos. La protección de datos desde el diseño, se ha convertido en un principio esencial de actividad empresarial e incentiva a las empresas a innovar y desarrollar nuevas ideas, métodos y tecnologías para asegurar y proteger los datos personales."

Reglamento Europeo